

The Practitioner's Blueprint for Secure AI

By John M. Willis, Quantum Powered Security, Inc.



August 2025

Copyright and License

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc.

This manuscript is licensed under the Creative Commons Attribution 4.0 International License (CC BY 4.0). You are free to share and adapt this work for any purpose, including commercial use, provided appropriate attribution is given.

License: <https://creativecommons.org/licenses/by/4.0/>

Patent Notice

The concepts, architectures, and reference designs presented in this work are intended to encourage adoption, adaptation, and further innovation. Readers are encouraged to tailor PBSAI to their own environments, products, and services. Novel implementations, extensions, and improvements developed by others may be eligible for intellectual property protection under applicable patent laws.

The authors likewise reserve all rights to pursue patent protection for their own inventions, implementations, improvements, and future developments related to PBSAI. Certain aspects of this work are the subject of pending patent applications. Except as expressly stated by applicable law, no patent rights are granted or implied by this publication or its CC BY 4.0 license.

Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem

Domain G – IR & Forensics

Table of Contents

Domain G - Incident Response & Digital Forensics (IR/DFIR)	4
G1. Incident Triage Agent	4
Agent Blueprint [Informative]	4
Technical Implementation Details (G1) [Informative]	15
MCP-Native Protocol Specification (G1) [Normative]	17
G2. Automated Containment Agent	18
Agent Blueprint [Informative]	18
Technical Implementation Details (G2) [Informative]	28
MCP-Native Protocol Specification (G2) [Normative]	30
G3. Recovery Orchestration Agent	31
Agent Blueprint [Informative]	31
Technical Implementation Details (G3) [Informative]	44
MCP-Native Protocol Specification (G3) [Normative]	46
G4. Forensic Analysis Agent	47
Agent Blueprint [Informative]	47
Technical Implementation Details (G4) [Informative]	61
MCP-Native Protocol Specification (G4) [Normative]	63
G5. RCA Analysis Agent	64
Agent Blueprint [Informative]	64
Technical Implementation Details (G5) [Informative]	75
MCP-Native Protocol Specification (G5) [Normative]	77
G6. Communications Agent	78
Agent Blueprint [Informative]	78
Technical Implementation Details (G6) [Informative]	89
MCP-Native Protocol Specification (G6) [Normative]	91

Domain G - Incident Response & Digital Forensics (IR/DFIR)

G1. Incident Triage Agent

Agent Blueprint [Informative]

Purpose: Ingest fresh detections/anomalies, classify and prioritize the incident, and draft a **ContainmentCommand** proposal for review.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **DetectionEvent** (SIEM/EDR pipeline; Kafka/OTel/Syslog JSON): detection_id, rule_id/name, severity, category, asset tuple (asset_id, ip, hostname), principal (user/service), event_ts, enrichment (process, parent pid, file hash, URL, etc.), pipeline name.
- **AuthAnomaly** (IdP/UEBA risk signals; REST/Stream): anomaly_id, user/principal, risk_score, signals, signin_context (event_id, app, ip, ASN, geo, time).

Model training / knowledge (what the LLM relies on):

- Style/prompt pack for IR triage rubric (MITRE ATT&CK mapping, priority matrix, containment playbook selection).
- RAG sources: detection rule catalog, case history, asset criticality ("CrownJewels" map), IdP risk taxonomy, containment playbooks; **do not** train on regulated evidence; fetch via evidence_refs.
- Guardrails: read-only against SIEM/IdP; **no direct containment execution**; tool scopes limited to correlation, scoring, and **draft proposal** generation.

Decisions it makes (deterministic + model-assisted):

- **Incident classification** (e.g., Ransomware.Lateral, PrivilegeMisuse.Local, AccountTakeover.Cloud) using rule metadata + ATT&CK mapping + correlation context.
- **Priority/severity adjustment** using asset criticality, user risk, signal quality, dwell time, and blast radius.

- **Containment proposal** selection: choose candidate playbook steps (e.g., isolate_host, suspend_user, block_token) **as a draft**; mark **requires co-sign** by PolicyAuthoringAgent per constraints.

Routing / where outputs go:

- **IncidentClassified** → IR workflow bus (Kafka/AMQP) and case management; side-effects: open/update IR case, attach evidence_refs and rationale.
- **Draft ContainmentCommand** → **Automated Containment Agent** (REST/gRPC) as a proposal; side-effects: add to case timeline; await co-sign gate.

Automation scope vs. manual/HITL:

- Fully automated: ingest, correlate, classify, score, draft proposal text, link evidence, open/update IR case.
- **HITL required:** any containment proposal that affects **CrownJewels** or high-blast-radius assets; ambiguous or low-confidence classifications; identity actions on executives.
- Manual outside agent: legal notification decisions, external communications, non-standard containment outside registered playbooks.

Security Domain: Incident Response & Digital Forensics (IR/DFIR)

Inputs (native protocols consumed) [Informative]

1. **DetectionEvent (SIEM/EDR)** — host/network detection events for correlation and classification.
2. **AuthAnomaly (IdP/UEBA)** — identity risk indicators to enrich triage and propose identity containment.

Example: Consumed Protocol — DetectionEvent (SIEM/EDR) [Informative]

Native payload

```
{
  "detection_id": "DET-2025-08-15-7711",
  "rule_id": "r-ssh-suspicious-execve",
  "rule_name": "Suspicious execve of passwd",
  "severity": "High",
```

```
"category": "PrivilegeModification",
"asset": {"asset_id": "srv-001", "ip": "10.2.14.5", "hostname": "srv-001"},
"principal": {"user": "jdoe"},
"event_ts": "2025-08-15T10:00:12Z",
"enr": {"process": "/usr/bin/passwd", "ppid": 1123},
"pipeline": "siem-pipeline"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-g1-triage-1111-2222-3333-4444",
    "thread_id": "uuid-det-DET-2025-08-15-7711",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "IncidentTriageAgent",
    "intent": "triage",
    "policy_refs": ["IR-4", "AU-6"],
    "constraints": ["policy_cosign:PolicyAuthoringAgent"],
    "decision_basis": {
      "evidence_refs": ["uri://kafka/detections/DET-2025-08-15-7711"],
      "confidence": 0.93,
      "explanation_ref": "uri://kb/triage/severity-matrix#host-privmod"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/ir/incident-triage-agent",
      "signing_kid": "kid-siem-g1-01",
      "attestation_ref": "uri://slsa/attestations/incident-triage@sha256:siem01"
    }
  }
}
```

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

```

    },
    "classification": "C2",
    "legal_hold": false
  },
  "native_payload": { ... }
}

```

Example: Consumed Protocol — AuthAnomaly (IdP/UEBA) [Informative]

Native payload

```

{
  "anomaly_id": "AUTH-ANOM-9021",
  "user": "E102993",
  "risk_score": 86,
  "signals": ["impossible_travel", "new_device"],
  "signin_context": {
    "event_id": "signin-9a12",
    "app": "gcp-console",
    "ip": "198.51.100.44",
    "asn": "AS15169",
    "geo": "US-CA",
    "time": "2025-08-15T10:00:15Z"
  }
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-g1-triage-1111-2222-3333-4444",

```

```

"thread_id": "uuid-auth-AUTH-ANOM-9021",
"task_id": "uuid-ee11-ff22-0011-2233",
"role": "IncidentTriageAgent",
"intent": "triage",
"policy_refs": ["IR-5", "IA-2"],
"constraints": ["policy_cosign:PolicyAuthoringAgent"],
"decision_basis": {
  "evidence_refs": [
    "uri://idp/anomalies/AUTH-ANOM-9021",
    "uri://idp/signin/signin-9a12"
  ],
  "confidence": 0.91,
  "explanation_ref": "uri://kb/triage/user-risk-correlation"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/ir/incident-triage-agent",
  "signing_kid": "kid-idp-g1-02",
  "attestation_ref": "uri://slsa/attestations/incident-triage@sha256:idp02"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **IncidentClassified** (Kafka/AMQP) with class, priority, evidence_refs.

- **ContainmentCommand (Draft)** (REST/gRPC) to Automated Containment Agent; includes actions, targets, and **requires co-sign** marker.

MCP context (required) [Informative]

mission_id; role="IncidentTriageAgent"; intent="triage";
constraints=["policy_cosign:PolicyAuthoringAgent"]; provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

policy_refs (IR-4, IR-5, AU-6, AC-6); classification (C1–C3; typically C2); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

Containment gateways/PEPs MUST verify the **PolicyAuthoringAgent** co-sign before executing any **ContainmentCommand** affecting protected assets.

NIST SP 800-160v2 linkage [Informative]

Detect/Respond — rapid classification and decision support to reduce attacker dwell and limit blast radius.

Automation feasibility [Informative]

High: classification and priority scoring are fully automatable; containment remains **proposal + co-sign** gated.

Output Contracts (merged) [Informative]

(OC-1/OC-2 are primary. OC-3..OC-6 are optional enterprise extensions.)

OC-1: IncidentClassified (IR workflow event) [Informative]

- **Producer(s):** G1
- **Topic/Path:** sec.ir.incident.classified (Kafka/AMQP)
- **Schema/Format:** IncidentClassified@1.0 (class, priority, evidence_refs, rationale_url)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-incident_id
- **Idempotency-Key:** sha256(incident_id, classification_version)

- **Ack/Nack:** broker ACK; NACK on schema reject → retry/backoff
- **Timeouts/Retry:** ack≤10s; exp-backoff≤5x
- **Side-Effects:** open/update IR case; attach decision_rationale_url
- **HITL Token:** none
- **Observability:** trace_id, mission_id, policy_refs, evidence_refs, decision_basis.*, classification_label, provenance.attestation
- **Retention/TTL:** 1 year (or per IR policy)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=IncidentClassified@1.0 | json_schema_uri=uri://schema/incident-classified-1.0.json | sha256= | producers=G1 | consumers=IR-Case-01, SIEM-01 | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: ContainmentProposalDraft (to Automated Containment Agent) [Informative]

- **Producer(s):** G1
- **Endpoint:** POST /containments/proposals or gRPC ContainmentService.Draft
- **Schema/Format:** ContainmentProposalDraft@1.0 (actions, targets, scope, rationale, requires_cosign=true, cosigners=[PolicyAuthoringAgent])
- **Classification:** C2+
- **Delivery:** exactly-once per action_id (consumer enforces idempotency)
- **Ordering:** per-incident_id
- **Idempotency-Key:** sha256(incident_id, target_id, action_set_hash)
- **Ack/Nack:** 202 Accepted / gRPC OK within 30 s; retry/backoff on NACK/timeout
- **Side-Effects:** append to IR case timeline; enqueue for co-sign validation
- **HITL Token:** required when CrownJewels in targets or model_confidence < theta_low
- **Observability:** trace_id, mission_id, policy_refs, evidence_refs, decision_basis.confidence, classification_label, provenance.attestation

- **Retention/TTL:** 7 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When `propose_containment=true` and scope affects production or protected assets

`schema_id=ContainmentProposalDraft@1.0 |`

`json_schema_uri=uri://schema/containment-proposal-1.0.json | sha256= |`

`producers=G1 | consumers=AutoContain-01 | accepts=1.0–1.x`

Conformance: Normative when condition is met.

OC-3: TriageDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** G1, IR-Portal-01
- **Topic/Path:** `sec.ir.triage.contestation`
- **Schema/Format:** `TriageDispute@1.0`
- **Classification:** C2
- **Delivery/Ordering:** `at-least-once; per-incident_id`
- **Idempotency-Key:** `sha256(incident_id, dispute_id)`
- **Ack/Nack:** `case_id` link required ≤ 30 s; `retry/backoff`
- **Side-Effects:** pause auto-escalations if severity disputed (policy-bound)
- **HITL Token:** required when severity would be reduced on CrownJewels
- **Observability:** `trace_id`, `mission_id`, `decision_rationale_url`
- **Retention/TTL:** 1 year

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability workflow is enabled

`schema_id=TriageDispute@1.0 | json_schema_uri=uri://schema/triage-dispute-1.0.json`

OC-4: IRCASELinkageEvent (SOC integration) [Informative, optional]

- **Producer(s):** G1
- **Topic/Path:** `sec.ir.case.linkage`

- **Schema/Format:** IRCaseLinkageEvent@1.0 (detection_id/anomaly_id ↔ case_id)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-link-id
- **Idempotency-Key:** sha256(case_id, source_id)
- **Ack/Nack:** broker ACK; retry/backoff
- **Side-Effects:** attach artifacts to case
- **Observability:** trace_id, mission_id
- **Retention/TTL:** 1 year

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When external IR/CMS integration is present

schema_id=IRCaseLinkageEvent@1.0 | json_schema_uri=uri://schema/ir-case-linkage-1.0.json

OC-5: ReclassificationReport (Drift/change management) [Informative, optional]

- **Producer(s):** G1
- **Topic/Path:** sec.ir.triage.reclassify
- **Schema/Format:** ReclassificationReport@1.0 (before/after, reason, impact)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-incident_id
- **Idempotency-Key:** sha256(incident_id, new_class, new_priority)
- **Ack/Nack:** broker ACK; retry/backoff
- **Side-Effects:** notify case owners; adjust SLAs
- **Observability:** trace_id, mission_id, change_impact_score
- **Retention/TTL:** 1 year

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When automated reclassification is enabled

schema_id=ReclassificationReport@1.0 |
json_schema_uri=uri://schema/reclassification-1.0.json

OC-6: AnalystFeedbackEvent (Stakeholder feedback loop) [Informative, optional]

- **Producer(s):** SOC portal; G1 (aggregation)
- **Topic/Path:** sec.ir.triage.feedback
- **Schema/Format:** AnalystFeedbackEvent@1.0 (label={helpful|neutral|harmful}, note)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-feedback-id
- **Idempotency-Key:** sha256(feedback_id, incident_id)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** enqueue for governance-reviewed learning updates
- **Observability:** trace_id, mission_id, artifact_id
- **Retention/TTL:** 1 year

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When analyst feedback workflow is enabled

schema_id=AnalystFeedbackEvent@1.0 | json_schema_uri=uri://schema/analyst-feedback-1.0.json

State machine (concise) [Informative]

states = { idle, ingesting_event, correlating, classifying, prioritizing, drafting_containment, awaiting_cosign, contestation_workflow, failed, closed }
transition(idle -> ingesting_event) when DetectionEvent or AuthAnomaly received
transition(ingesting_event -> correlating) when correlation window opens
transition(correlating -> classifying) when sufficient signals gathered
transition(classifying -> prioritizing) when class determined
transition(prioritizing -> drafting_containment) when priority >= P2 and playbook match found
transition(drafting_containment -> awaiting_cosign) when proposal emitted with requires_cosign=true

transition(classifying -> contestation_workflow) when dispute opened or
 disagreement_score >= 0.5
 transition(* -> failed) on schema/timeout/validation error
 timeout(awaiting_cosign, 30m) -> failed; retry <= 3 with exp backoff
 idempotency_key(OC-1) = sha256(incident_id, classification_version)
 idempotency_key(OC-2) = sha256(incident_id, target_id, action_set_hash)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 IncidentClassified	Required	Always	Core IR routing and SLAs
OC-2 ContainmentProposalDraft	Conditionally Required	propose_containment=true AND scope includes protected/production	Enforcement gating via co-sign
OC-3 TriageDispute	Optional	Contestability enabled	Governance & explainability
OC-4 IRCASELinkageEvent	Optional	External IR/CMS integration present	Case artifact traceability
OC-5 ReclassificationReport	Conditionally Required	Automated reclassification enabled	Risk & SLA realignment
OC-6 AnalystFeedbackEvent	Optional	Analyst feedback workflow enabled	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- policy_refs: IR-4, IR-5, AU-6, AC-6 (+ internal IR standards)
- **HITL required:** actions on CrownJewels; identity suspensions for executives; model_confidence < theta_low; conflicting evidence
- Automatic HITL triggers: stakeholder_disagreement_score >= 0.5; model_drift_detected=true; legal_hold=true (if breach suspected)
- Manual outside agent: breach declaration, regulatory notifications, custom playbooks

SLOs and KPIs [Informative]

- TriageLatency_p95 <= 60 s from first signal
- ProposalDraftLatency_p95 <= 120 s when propose_containment=true
- MisclassificationRate_7d <= 3 percent
- FalseContainmentProposalRate_7d <= 1 percent
- ReclassificationAfterContainmentRate_30d <= 2 percent

Outputs index [Informative]

[OC-1 IncidentClassified], [OC-2 ContainmentProposalDraft], [OC-3 TriageDispute], [OC-4 IRCASELinkageEvent], [OC-5 ReclassificationReport], [OC-6 AnalystFeedbackEvent]

Technical Implementation Details (G1) [Informative]

Model and training profile [Informative]

model_id=ir-triage-text-model; temperature=0.1; max_tokens_out=700
 prompt_pack_id=ir-triage-v1 (rubric: ATT&CK mapping, priority matrix, playbook selector)
 RAG: sources={rule catalog, case history, asset criticality, IdP risk taxonomy, playbooks}; max_docs=10; min_similarity=0.78; citations required
 fine_tuning/adapters: optional small adapters on internal case summaries; exclude regulated or PII-rich artifacts; eval on precision/recall and hallucination bounds
 guardrails: no execution tools; only draft containment; scoped tokens to SIEM/IdP read and IR/CMS write

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal (signals, correlations, classifications,

proposals), ttl=365d
semantic_memory: namespaces=["detections","cases","assets","playbooks"];
embeddings=text-embedding-sec-v1; k=10
durable_state_store: event-sourced journal; snapshot on classification_version
increments
consistency: at-least-once (OC-1); exactly-once (OC-2)
idempotency: per Output Contracts

Decision and routing logic [Informative]

$priority_score = 0.35severity_weight + 0.25asset_criticality + 0.2risk_score + 0.1signal_quality + 0.1*dwelt_time_weight$
where:

- severity_weight in {Low=0.2, Med=0.5, High=0.8, Critical=1.0}
- asset_criticality in [0..1] (CrownJewels >= 0.9)
- risk_score normalized to [0..1] from IdP/UEBA
- signal_quality = model_confidence * rule_precision_estimate
- dwelt_time_weight = min(1, hours_since_first_signal / 24)

propose_containment = (priority_score >= 0.65) AND playbook_match=true

Model Risk Management [Informative]

continuous_validation: daily; eval_suite=[goldens, adversarial, noisy-signal]
thresholds: eval_pass_rate >= 99.0 percent → auto_HITL if below
red_team_cycle: monthly ATT&CK stream replays
rollback_policy: eval_drop >= 1.5 percentage points for 48 h → revert model_id; notify
owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: “who/what/why” + evidence_refs + ATT&CK techniques +
hashes
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL; stable field order; retention per classification and legal_hold

Incident Response Integration [Informative]

emit OC-1 to IR bus; create/update case_id; attach correlations and rationale
on OC-2 ACK: record proposal_id, required cosigners, and SLA timers

Change Impact / Reclassification [Informative]

on new evidence: recompute priority_score; if class/priority changes → emit OC-5

Stakeholder Feedback Loop [Informative]

collect AnalystFeedbackEvent (OC-6); governance-reviewed updates to prompt_pack/playbook hints; no auto-training on regulated data

Data Sovereignty and Legal Hold [Informative]

tag artifacts with region; restrict egress; legal_hold=true → freeze deletion and extend TTLs

Interfaces (links only) [Informative]

Consumes: DetectionEvent (SIEM/EDR), AuthAnomaly (IdP/UEBA)

Produces: OC-1 IncidentClassified; OC-2 ContainmentProposalDraft; optional OC-3..OC-6 as adopted

Safety and abuse prevention [Informative]

kill_switch: disable proposals if provenance invalid or cosigners unavailable

blast-radius caps: max N proposals/hour that touch CrownJewels without human approval

cost/QPS limits per mission_id; anomaly alerts on spikes

Testing and validation [Informative]

contract tests for all OCs; offline replay of historical incidents; red-team drills; drift checks and rollback

Deployment and lifecycle [Informative]

HPA on queue depth; concurrency cap for correlation stage; canary model rollout; SBOM + in-toto/SLSA attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-61 Rev. 2; NIST SP 800-53 Rev. 5 (IR, AU, AC); NIST SP 800-137; MITRE ATT&CK/D3FEND; NIST CSF 2.0; ISO/IEC 27035

MCP-Native Protocol Specification (G1) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** DetectionEvent (SIEM/EDR); AuthAnomaly (IdP/UEBA)
- **Native Protocol(s) Produced:** IncidentClassified (Kafka/AMQP); ContainmentProposalDraft (REST/gRPC)
- **MCP Context Fields:**
 - **Required:** mission_id; role="IncidentTriageAgent"; intent="triage"; constraints=["policy_csign:PolicyAuthoringAgent"]; provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** policy_refs (IR-4, IR-5, AU-6, AC-6); classification (C1–C3; typically C2); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold
- **Enforcement Note:** PEPs MUST enforce co-sign from PolicyAuthoringAgent before Automated Containment executes a ContainmentCommand.
- **Versioning and compatibility; producers/consumers registry:** authoritative in the schema registry (see Schema Capsules for accepted ranges/EOL).
- **Example payloads:** authoritative native + MCP-wrapped examples as provided above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

G2. Automated Containment Agent

Agent Blueprint [Informative]

Purpose: Execute approved containment actions (host isolation, user disable, IP block, process kill, mailbox quarantine, etc.) and emit outcomes with a rollback token.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **ContainmentCommand** (REST/gRPC) — command_id, incident_id, actions[], targets[], approvals (incl. **policy co-sign**), constraints (timebox, blast-radius, rollback requirements), rationale, evidence_refs.
- **Actuator capabilities registry** (read): per-vendor API, scopes, rate limits, idempotency semantics, supported actions and prechecks.

- **CrownJewels / asset criticality map** (read): determines blast-radius caps and HITL gates.

Model training / knowledge (what the LLM relies on):

- Execution planning rubric (safe ordering: identity first vs. network first, dependency checks, pre/post-verification).
- RAG sources: actuator API docs, internal playbooks, failure runbooks, historical success/failure telemetry; **no** secrets in training; fetch credentials via secrets manager at runtime.
- Guardrails: **must validate co-sign**; enforce constraints; deny unregistered actuators/actions; canary mode when required.

Decisions it makes (deterministic + model-assisted):

- **Execution plan synthesis:** order actions to minimize blast radius (e.g., suspend credentials → then isolate host).
- **Actuator selection & fallback:** choose primary vendor; if failure or policy-disallowed, select compliant fallback.
- **Timeboxing & retries:** derive per-action timeout and exponential backoff respecting constraints.
- **Verification & rollback readiness:** verify effect (e.g., EDR isolation state=isolated), and mint **RollbackToken** scoped to actions.

Routing / where outputs go:

- **ActionOutcome** → IR bus (Kafka/AMQP) and case management; attach actuator evidence_refs.
- **RollbackToken** → secrets/object store; reference emitted with outcome for controlled reversal.
- **Actuator control-plane calls** → EDR/PAM/IdP/SDN/Firewall/Email vendors (REST/gRPC) with signed provenance; responses linked as evidence_refs.

Automation scope vs. manual/HITL:

- Fully automated: plan → prechecks → execute → verify → emit outcomes; mint rollback token.
- **HITL required:** actions touching **CrownJewels**, mailbox quarantine for executives, network blocks affecting critical segments, or when model_confidence < theta_low.

- Manual outside agent: regulatory notifications, exception approvals for off-catalog actions.

Security Domain: Incident Response & Digital Forensics (IR/DFIR)

Inputs (native protocols consumed) [Informative]

1. **ContainmentCommand (REST/gRPC)** — authorized command from triage/governance.

Example: Consumed Protocol — ContainmentCommand (REST/gRPC)

[Informative]

Native payload

```
{
  "command_id": "CC-2025-08-15-0049",
  "incident_id": "INC-45877",
  "requested_by": "IncidentTriageAgent",
  "requested_at": "2025-08-15T10:01:00Z",
  "priority": "High",
  "targets": [
    {"type": "asset", "asset_id": "srv-001", "ip": "10.2.14.5", "platform": "linux"},
    {"type": "principal", "employee_id": "E102993"}
  ],
  "actions": [
    {"type": "isolate_host", "actuator": "edr", "vendor": "CrowdStrike", "policy": "isolate_and_monitor"},
    {"type": "disable_user", "actuator": "idp", "vendor": "Okta", "policy": "suspend_and_revoke_tokens"}
  ],
  "scope": "asset_and_user",
  "constraints": ["timebox_5m", "max_blast_radius:asset", "must_rollback_token:true"],
  "rationale": "Privilege modification on srv-001 and concurrent high-risk auth anomaly."
}
```

```

"evidence_refs": [
  "uri://kafka/detections/DET-2025-08-15-7711",
  "uri://idp/anomalies/AUTH-ANOM-9021",
  "uri://idp/signin/signin-9a12"
],
"approvals": {
  "change_ref": "CHG0054322",
  "risk_owner": "security.lead",
  "policy_agent_cosign": {"alg": "ES256", "jws":
"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...."}
},
"rollback_plan": {
  "methods": [
    {"type": "release_isolation", "actuator": "edr"},
    {"type": "enable_user", "actuator": "idp"}
  ],
  "token_ttl_seconds": 7200
}
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-g2-contain-1111-2222-3333-4444",
    "thread_id": "uuid-inc-INC-45877",
    "task_id": "uuid-aaaa-bbbb-cccc-dddd",
    "role": "AutomatedContainmentAgent",

```

```

"intent": "contain",
"policy_refs": ["IR-4", "IR-5", "AC-6", "SC-7"],
"constraints": ["timebox_5m", "max_blast_radius:asset", "must_rollback_token:true"],
"decision_basis": {
  "evidence_refs": [
    "uri://kafka/detections/DET-2025-08-15-7711",
    "uri://idp/anomalies/AUTH-ANOM-9021",
    "uri://idp/signin/signin-9a12"
  ],
  "confidence": 0.95,
  "explanation_ref": "uri://kb/containment/playbooks/host-isolation-and-user-suspend"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/ir/automated-containment-agent",
  "signing_kid": "kid-contain-g2-01",
  "attestation_ref": "uri://slsa/attestations/automated-containment@sha256:contain01"
},
"classification": "C2",
"legal_hold": true
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **ActionOutcome** (Kafka/AMQP/REST) including actuator evidence and verification results.
- **RollbackToken** (stored in secret/object store; reference emitted) for controlled reversal.

- **Actuator control-plane calls** to EDR/PAM/IdP/SDN/Firewall/Email (vendor REST/gRPC); responses logged as evidence_refs.

MCP context (required) [Informative]

mission_id; role="AutomatedContainmentAgent"; intent="contain";
decision_basis.evidence_refs; provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

policy_refs (IR-4, IR-5, AC-6, SC-7); classification (typically C2; C3 if user data involved); constraints (e.g., timebox_5m, max_blast_radius:asset, canary_required:false); legal_hold

Enforcement note [Informative]

Before executing **any** action: verify **policy_agent_cosign** (valid JWS, expected KID, unexpired), confirm constraints, and ensure **RollbackToken** can be minted (or preexisting and valid) for reversible actions.

NIST SP 800-160v2 linkage [Informative]

Respond & Recover — bounded, reversible actions with assured rollback and provenance.

Automation feasibility [Informative]

High: execution is automated with structured fallbacks; actuator failures trigger policy-governed degraded modes and notifications.

Output Contracts (merged) [Informative]

(OC-1/OC-2 are primary. OC-3..OC-6 are optional enterprise extensions.)

OC-1: ActionOutcome (execution + verification result) [Informative]

- **Producer(s):** G2
- **Topic/Path:** sec.ir.containment.outcome (Kafka/AMQP) or POST /containments/outcomes
- **Schema/Format:** ActionOutcome@1.1 (command_id, incident_id, actions[], per-action status, verification, evidence_refs[], rollback_token_ref, error_detail?)
- **Classification:** C2 (C3 if includes user identifiers beyond employee_id)
- **Delivery:** at-least-once

- **Ordering:** per-command_id
- **Idempotency-Key:** sha256(command_id, plan_version)
- **Ack/Nack:** broker ACK or HTTP 201; schema reject → NACK and retry/backoff
- **Timeouts/Retry:** ack<=20s; exp-backoff<=5x; dead-letter after 30m
- **Side-Effects:** update IR case timeline; notify triage/governance on failure/high-blast actions
- **HITL Token:** required when verification indicates partial success on CrownJewels
- **Observability:** trace_id, mission_id, policy_refs, decision_basis.*, classification_label, provenance.attestation
- **Retention/TTL:** 7 years (breach investigations)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=ActionOutcome@1.1 | json_schema_uri=uri://schema/action-outcome-1.1.json | sha256= | producers=G2 | consumers=IR-Case-01, G1, Audit-Journal-01 | accepts=1.0–1.1 (1.0 EOL 2027-01-01)

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: RollbackToken (scoped reversal capability) [Informative]

- **Producer(s):** G2
- **Location:** secrets/object store (secret://rollbacks/{command_id}/{token_id})
- **Schema/Format:** RollbackToken@1.0 (token_id, command_id, action_set_hash, scope, methods[], valid_until, nonce, audit_ref)
- **Classification:** C2+ (treat as secret)
- **Delivery:** exactly-once (write); reference emitted via OC-1
- **Ordering:** per-command_id
- **Idempotency-Key:** sha256(command_id, action_set_hash)
- **Ack/Nack:** 201 Created; on failure: retry/backoff and **do not** execute irreversible steps

- **Side-Effects:** register token in audit journal; bind to approvals and constraints
- **HITL Token:** required to redeem when CrownJewels involved unless emergency window active
- **Observability:** trace_id, mission_id, provenance.attestation
- **Retention/TTL:** per rollback_plan.token_ttl_seconds (default 2 h) or legal_hold override

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When actions include any reversible step or constraints include must_rollback_token:true

schema_id=RollbackToken@1.0 | json_schema_uri=uri://schema/rollback-token-1.0.json | sha256= | producers=G2 | consumers=G2, IR-Case-01 | accepts=1.0

Conformance: Normative when condition is met.

OC-3: ContainmentFailureEvent (SOC/PEP escalation) [Informative, optional]

- **Producer(s):** G2
- **Topic/Path:** sec.ir.containment.failure
- **Schema/Format:** ContainmentFailureEvent@1.0 (command_id, action, actuator, reason, next_action)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-action_id
- **Idempotency-Key:** sha256(command_id, action_id, failure_code)
- **Ack/Nack:** broker ACK; retry/backoff
- **Side-Effects:** open P1 on-call page to actuator owner
- **Observability:** trace_id, mission_id
- **Retention/TTL:** 1 year

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When external paging/PEP integration is present

schema_id=ContainmentFailureEvent@1.0 |
json_schema_uri=uri://schema/containment-failure-1.0.json

OC-4: RollbackExecutedEvent (restoration audit) [Informative, optional]

- **Producer(s):** G2
- **Topic/Path:** sec.ir.containment.rollback
- **Schema/Format:** RollbackExecutedEvent@1.0 (token_id, redeemed_by, time, methods_applied, result)
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per-token_id
- **Idempotency-Key:** sha256(token_id, redeem_nonce)
- **Ack/Nack:** broker ACK; retry/backoff
- **Side-Effects:** close rollback window; update case
- **Observability:** trace_id, mission_id, provenance.attestation
- **Retention/TTL:** 7 years (if breach); else 1 year

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When rollback capability is enabled

schema_id=RollbackExecutedEvent@1.0 | json_schema_uri=uri://schema/rollback-executed-1.0.json

State machine (concise) [Informative]

states = { idle, validating_command, staging_rollback, executing, verifying, emitting_outcome, awaiting_rollback, failed, closed }
transition(idle -> validating_command) when ContainmentCommand received
transition(validating_command -> staging_rollback) when co_sign_valid=true AND constraints_ok=true
transition(staging_rollback -> executing) when rollback_token_created=true OR all_actions_irreversible=false
transition(executing -> verifying) when action_batch_complete=true
transition(verifying -> emitting_outcome) when verification_passed in {all,partial,none}
transition(emitting_outcome -> awaiting_rollback) when any reversible action executed
transition(awaiting_rollback -> closed) when rollback_expired OR token_redeemed=false after ttl
transition(* -> failed) on actuator_error[non-retryable] OR schema_invalid OR

cosign_invalid

timeout(executing, timebox) -> failed; retry <= retries_max with exp backoff

idempotency_key(OC-1) = sha256(command_id, plan_version)

idempotency_key(OC-2) = sha256(command_id, action_set_hash)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 ActionOutcome	Required	Always	Core IR visibility & audit
OC-2 RollbackToken	Conditionally Required	Reversible actions or must_rollback_token:true	Safe restoration capability
OC-3 ContainmentFailureEvent	Optional	Paging/PEP integration present	Rapid escalation on failures
OC-4 RollbackExecutedEvent	Optional	Rollback capability enabled	Restoration audit & closure

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: IR-4, IR-5, AC-6, SC-7 (+ internal playbooks)
- **HITL required:** actions on CrownJewels; quarantine executive mailboxes; broad SDN blocks; model_confidence < theta_low
- Automatic HITL triggers: cosign_missing_or_invalid=true; actuator_risk_score > threshold; legal_hold=true

- Manual outside agent: emergency exceptions beyond catalog; irreversible actions without rollback path

SLOs and KPIs [Informative]

- ContainmentExecuteAck_p95 <= 60 s (from command receipt)
- VerificationPassRate_7d >= 98 percent
- FailedActionRate_7d <= 2 percent
- RollbackTokenIssueLatency_p95 <= 5 s
- SuccessfulRollbackRate_30d >= 99 percent

Outputs index [Informative]

[OC-1 ActionOutcome], [OC-2 RollbackToken], [OC-3 ContainmentFailureEvent], [OC-4 RollbackExecutedEvent]

Technical Implementation Details (G2) [Informative]

Model and training profile [Informative]

model_id=containment-planner; temperature=0.05; max_tokens_out=600
 prompt_pack_id=containment-exec-v1 (ordering rubric, precheck/verify checklists)
 RAG: sources={actuator API registry, internal playbooks, failure runbooks, telemetry} ;
 max_docs=12; min_similarity=0.8
 fine_tuning/adapters: optional small adapters on anonymized execution logs; eval on plan safety and success rate
 guardrails: enforce cosign + constraints; deny off-catalog actions; canary_required=true by default on CrownJewels

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal (commands, plans, evidence_refs, outcomes), ttl=365d
 semantic_memory: namespaces=["actuators","playbooks","telemetry"];
 embeddings=text-embedding-sec-v1; k=12
 durable_state_store: event-sourced; snapshot per plan_version
 consistency: at-least-once (OC-1); exactly-once (OC-2 write)
 idempotency: per Output Contracts

Decision and routing logic [Informative]

blast_radius_score = 0.5*asset_criticality* + 0.3*action_scope* + 0.2**dependency_risk*
execute_order = sort_by(*action_safety_score* DESC, *prereq_satisfied* DESC,
blast_radius_score ASC)
rollback_required = (any action reversible) OR constraint "must_rollback_token:true"
canary_required = constraint "canary_required:true" OR CrownJewels==true

Model Risk Management [Informative]

continuous_validation: daily simulation with vendor sandboxes
thresholds: plan_safety_eval >= 99.0 percent → else auto_HITL
red_team_cycle: monthly actuator API fuzzing and failure-injection
rollback_policy: revert model_id if plan_failure_rate_24h > 2 percent

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: plan steps, prechecks, verifications, constraints satisfied, co-sign details
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL with per-action evidence_refs; retain per legal_hold

Incident Response Integration [Informative]

post OC-1 to IR bus; update case; notify triage and governance on partial/failed outcomes

Rollback & Restoration [Informative]

mint OC-2 token before reversible actions; redeem requires authorizations; on redeem → emit OC-4

Data Sovereignty and Legal Hold [Informative]

regional actuator selection where applicable; legal_hold=true → extend TTLs and disable token destruction

Interfaces (links only) [Informative]

Consumes: ContainmentCommand (REST/gRPC)
Produces: OC-1 ActionOutcome; OC-2 RollbackToken; optional OC-3/OC-4

Safety and abuse prevention [Informative]

kill_switch: disable execution if provenance invalid or schema drift; circuit breaker on high failure rate
caps: max concurrent actions on CrownJewels per hour; SDN block prefixes limited by policy

Testing and validation [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

contract tests for OCs; sandbox rehearsals; chaos tests for actuator outages; replay historical incidents

Deployment and lifecycle [Informative]

HPA on command queue; canary rollout of planner; SBOM and SLSA attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-61 Rev. 2; NIST SP 800-53 Rev. 5 (IR, AC, SC); NIST SP 800-137; NIST SP 800-207; MITRE ATT&CK/D3FEND

MCP-Native Protocol Specification (G2) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** ContainmentCommand (REST/gRPC)
- **Native Protocol(s) Produced:** ActionOutcome (Kafka/AMQP/REST); RollbackToken (secrets/object store reference)
- **MCP Context Fields:**
 - **Required:** mission_id; role="AutomatedContainmentAgent"; intent="contain"; decision_basis.evidence_refs; provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** policy_refs (IR-4, IR-5, AC-6, SC-7); classification (C2 default; C3 if user data); constraints; legal_hold
- **Enforcement Note:** Must validate **policy co-sign** and constraints prior to execution; must mint and bind **RollbackToken** for reversible steps; must record actuator evidence_refs.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry (see Schema Capsules).
- **Example payloads:** authoritative native + MCP-wrapped examples as provided.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url for downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

G3. Recovery Orchestration Agent

Agent Blueprint [Informative]

Purpose: Coordinate and execute system/application recovery after containment: restore data, redeploy services, re-point traffic, and verify RTO/RPO compliance.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Recovery Plans (Runbooks via REST/Git):** plan_id, service, version, RTO/RPO targets, scope (env/regions), ordered steps (restore, redeploy, switch_traffic, verify), approvals, test_mode flag, last_tested timestamp.
- **DR State (Backup Catalog, Replication/DR-site health via REST/Stream):** snapshot age and integrity, replication lag, DR site readiness/capacity, dependency health.

Model training / knowledge (what the LLM relies on):

- Runbook execution rubric (prechecks, ordering, parallelism, verification, backout).
- RAG sources: runbook repo history, backup catalog index, IaC/CD pipeline docs, DNS/traffic-manager APIs, prior DR drill outcomes; do not train on customer data or secrets; fetch via evidence_refs.
- Guardrails: enforce **constraints** (RTO/RPO, change_window), deny off-runbook actions, require integrity verification when must_verify_integrity:true, never handle raw credentials (use secrets manager).

Decisions it makes (deterministic + model-assisted):

- **Eligibility and plan selection:** verify snapshot age vs. RPO, replication lag, DR-site health, dependency readiness.
- **Execution planning:** order and parallelize steps (e.g., restore DB → redeploy → warm-up → health-checks → traffic shift).
- **Cutover strategy:** choose weighted-DNS vs. blue/green vs. route policy roll; evaluate canary size and ramp schedule.
- **Backout/rollback:** if verification fails or SLOs not met, trigger backout per runbook.

Routing / where outputs go:

- **RecoveryActionOutcome** → IR/DR bus and case/ticketing; includes achieved RTO/RPO, verification results, evidence_refs.
- **Orchestrator calls** → backup/restore systems, IaC/CD, and DNS/traffic managers; responses captured as evidence_refs.
- **Optional events** → CutoverCompleted, DRRunbookDeviation, DataIntegrityReport.

Automation scope vs. manual/HITL:

- Fully automated: eligibility checks, restore, redeploy, verification, progressive traffic shift under low risk.
- **HITL required:** business cutover on customer-facing services, data integrity uncertainty, dependency degradation, or when recovery changes schema.
- Manual outside agent: regulatory/customer comms, declaring disaster, approving permanent topology changes.

Security Domain: Incident Response & Digital Forensics (IR/DFIR)

Inputs (native protocols consumed) [Informative]

1. **Recovery Plans (Runbooks from DR platform or Git; JSON/YAML via REST)** — authoritative steps and SLAs.
2. **DR State (Backup catalog, replication/DR-site health; REST/Stream)** — real-time readiness and integrity.

Example: Consumed Protocol — Recovery Plans (Runbooks via REST/Git)

[Informative]

Native payload

```
{  
  "plan_id": "RP-2025-08-15-PAYMENTS-AZ1",  
  "service": "payments-api",  
  "version": "3.2.1",  
  "rto_target_minutes": 30,  
  "rpo_target_minutes": 5,  
}
```

```
"scope": {
  "env": "production",
  "region_primary": "us-east-1",
  "region_dr": "us-west-2"
},
"steps": [
  {
    "order": 1,
    "action": "restore_snapshot",
    "target": "db-payments",
    "engine": "aurora",
    "snapshot_id": "snap-0abc123def",
    "prechecks": ["kms-key-available", "snapshot-integrity:verified"]
  },
  {
    "order": 2,
    "action": "redeploy",
    "target": "k8s",
    "namespace": "payments",
    "workload": "api",
    "image_tag": "3.2.1",
    "config_overrides": {"DB_HOST": "payments-dr.cluster.local"}
  },
  {
    "order": 3,
    "action": "switch_traffic",
    "method": "dns-weighted",
```

```

    "provider": "route53",
    "ttl_seconds": 60,
    "weights": {"dr": 100, "primary": 0}
  }
],
"approvals": ["dr.manager", "payments.owner"],
"test_mode": false,
"last_tested": "2025-07-20T02:10:00Z"
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-g3-recover-1111-2222-3333-4444",
    "thread_id": "uuid-plan-RP-2025-08-15-PAYMENTS-AZ1",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "RecoveryOrchestrationAgent",
    "intent": "recover",
    "policy_refs": ["CP-2", "CP-10"],
    "constraints": ["rto_target_minutes:30", "rpo_target_minutes:5",
"change_window:immediate", "must_verify_integrity:true"],
    "decision_basis": {
      "evidence_refs": ["uri://git/dr/runbooks/RP-2025-08-15-PAYMENTS-AZ1.json"],
      "confidence": 0.97,
      "explanation_ref": "uri://kb/dr/runbook-validation#payments-api"
    },
  },
  "provenance": {

```

```

    "producer_spiffe": "spiffe://enterprise/ir/recovery-orchestration-agent",
    "signing_kid": "kid-runbook-g3-01",
    "attestation_ref": "uri://slsa/attestations/recovery-orchestration@sha256:runbook01"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { /* same object as above */ }
}

```

Example: Consumed Protocol — DR State (Backup Catalog & Replication/DR Health) [Informative]

Native payload

```

{
  "timestamp": "2025-08-15T10:07:00Z",
  "backup_catalog": [
    {
      "asset_id": "db-payments",
      "snapshot_id": "snap-0abc123def",
      "taken_at": "2025-08-15T10:00:10Z",
      "age_seconds": 410,
      "integrity": "verified",
      "storage": "s3://backups/payments/",
      "encryption_kms_key": "arn:aws:kms:us-west-2:111122223333:key/abcd-1234"
    }
  ],
  "replication": {
    "cluster": "payments-prod",

```

```

    "lag_seconds": 180,
    "mode": "async"
  },
  "dr_site": {
    "region": "us-west-2",
    "ready": true,
    "capacity_ok": true,
    "last_failover_test": "2025-08-01T03:00:00Z"
  },
  "dependencies": [
    {"service": "auth", "status": "available"},
    {"service": "queue", "status": "degraded"}
  ]
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-g3-recover-1111-2222-3333-4444",
    "thread_id": "uuid-drstate-payments-prod-2025-08-15T10:07:00Z",
    "task_id": "uuid-ee11-ff22-0011-2233",
    "role": "RecoveryOrchestrationAgent",
    "intent": "recover",
    "policy_refs": ["CP-9", "CP-10"],
    "constraints": ["rto_target_minutes:30", "rpo_target_minutes:5",
    "must_verify_integrity:true"],
    "decision_basis": {

```

```

    "evidence_refs": [
      "uri://backup/catalog/db-payments/snap-0abc123def",
      "uri://replication/status/payments-prod",
      "uri://dr/site/us-west-2/health"
    ],
    "confidence": 0.95,
    "explanation_ref": "uri://kb/dr/eligibility-checks#snapshot-age-and-lag"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/ir/recovery-orchestration-agent",
    "signing_kid": "kid-drstate-g3-02",
    "attestation_ref": "uri://slsa/attestations/recovery-orchestration@sha256:drstate02"
  },
  "classification": "C2",
  "legal_hold": true
},
"native_payload": { /* same object as above */ }
}

```

Outputs (native) [Informative]

- **RecoveryActionOutcome** to IR/DR bus (Kafka/AMQP/REST) with achieved RTO/RPO and verification evidence.
- **Orchestrator calls** to backup/restore, IaC/CD, DNS/traffic managers (vendor REST/gRPC); responses are captured as evidence_refs.

MCP context (required) [Informative]

mission_id; role="RecoveryOrchestrationAgent"; intent="recover"; constraints including time/SLA targets (e.g., rto_target_minutes, rpo_target_minutes, change_window, must_verify_integrity); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

policy_refs (CP-2, CP-9, CP-10); classification (C2 typical; C3 if customer data in evidence); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

Before cutover: verify snapshot integrity, RPO met, DR site ready, dependency health within thresholds; enforce change_window and obtain required approvals.

NIST SP 800-160v2 linkage [Informative]

Respond & Recover with assured restoration; aligns to NIST SP 800-34 and SP 800-53 CP family objectives.

Automation feasibility [Informative]

High: runbook-driven execution with policy gates for business cutover and integrity confirmations.

Output Contracts (merged) [Informative]

(OC-1/OC-2 are primary. OC-3..OC-6 are optional enterprise extensions.)

OC-1: RecoveryActionOutcome (execution + verification result) [Informative]

- **Producer(s):** G3
- **Topic/Path:** sec.dr.recovery.outcome (Kafka/AMQP) or POST /recovery/outcomes
- **Schema/Format:** RecoveryActionOutcome@1.1 (plan_id, incident_id, steps[], per-step status, achieved_rto_minutes, achieved_rpo_minutes, verification_results, evidence_refs[], backout_performed?)
- **Classification:** C2 (C3 if evidence contains customer data)
- **Delivery:** at-least-once
- **Ordering:** per-plan_id
- **Idempotency-Key:** sha256(plan_id, plan_version, execution_id)
- **Ack/Nack:** broker ACK or HTTP 201; schema reject → NACK and retry/backoff
- **Timeouts/Retry:** ack<=20s; exp-backoff<=5x; dead-letter after 30m
- **Side-Effects:** update DR case/tickets; notify owners on RTO/RPO miss; attach decision_rationale_url
- **HITL Token:** required when cutover on customer-facing services

- **Observability:** trace_id, mission_id, policy_refs, decision_basis.*, classification_label, provenance.attestation
- **Retention/TTL:** 7 years if legal_hold, else 1 year

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=RecoveryActionOutcome@1.1 | json_schema_uri=uri://schema/recovery-action-outcome-1.1.json | sha256= | producers=G3 | consumers=IR-Case-01, DR-Board-01, Audit-Journal-01 | accepts=1.0–1.1 (1.0 EOL 2027-01-01)

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: CutoverCompleted (traffic shift and service acceptance) [Informative]

- **Producer(s):** G3
- **Topic/Path:** sec.dr.recovery.cutover
- **Schema/Format:** CutoverCompleted@1.0 (plan_id, execution_id, method, ramp_schedule, final_weights, health_checks, acceptance_criteria_met, start_ts, end_ts)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-execution_id
- **Idempotency-Key:** sha256(execution_id, cutover_version)
- **Ack/Nack:** broker ACK; retry/backoff
- **Side-Effects:** close change window; update SLAs; snapshot post-cutover state
- **HITL Token:** required if service is customer-facing or CrownJewels
- **Observability:** trace_id, mission_id, policy_refs, decision_basis.*, provenance.attestation
- **Retention/TTL:** 1 year

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When any step performs traffic switch or production cutover

schema_id=CutoverCompleted@1.0 | json_schema_uri=uri://schema/cutover-

completed-1.0.json | sha256= | producers=G3 | consumers=Change-Mgmt-01, IR-Case-01 | accepts=1.0

Conformance: Normative when condition is met.

OC-3: RecoveryDispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** G3, DR-Portal-01
- **Topic/Path:** sec.dr.recovery.contestation
- **Schema/Format:** RecoveryDispute@1.0 (execution_id, dispute_id, rationale, requested_action)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-execution_id
- **Idempotency-Key:** sha256(execution_id, dispute_id)
- **Ack/Nack:** case_id link $\leq$ 30 s; retry/backoff
- **Side-Effects:** pause further cutover steps until resolved
- **Observability:** trace_id, mission_id, decision_rationale_url
- **Retention/TTL:** 1 year

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability workflow is enabled

schema_id=RecoveryDispute@1.0 | json_schema_uri=uri://schema/recovery-dispute-1.0.json

OC-4: DRRunbookDeviationEvent (drift/change management) [Informative, optional]

- **Producer(s):** G3
- **Topic/Path:** sec.dr.runbook.deviation
- **Schema/Format:** DRRunbookDeviationEvent@1.0 (plan_id, step_id, deviation_type, reason, impact)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-step_id

- **Idempotency-Key:** sha256(plan_id, step_id, deviation_type)
- **Ack/Nack:** broker ACK; retry/backoff
- **Side-Effects:** open PR against runbook; trigger review
- **Observability:** trace_id, mission_id
- **Retention/TTL:** 1 year

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When automatic drift detection is enabled

schema_id=DRRunbookDeviationEvent@1.0 | json_schema_uri=uri://schema/dr-runbook-deviation-1.0.json

OC-5: DataIntegrityReport (post-restore assurance) [Informative, optional]

- **Producer(s):** G3
- **Topic/Path:** sec.dr.integrity.report
- **Schema/Format:** DataIntegrityReport@1.0 (checksums, rowcounts, referential_checks, application_consistency, sample_queries)
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per-execution_id
- **Idempotency-Key:** sha256(execution_id, integrity_suite_version)
- **Ack/Nack:** broker ACK; retry/backoff
- **Side-Effects:** gate cutover if must_verify_integrity:true and report != pass
- **Observability:** trace_id, mission_id, provenance.attestation
- **Retention/TTL:** 7 years if legal_hold; else 1 year

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When constraint includes must_verify_integrity:true

schema_id=DataIntegrityReport@1.0 | json_schema_uri=uri://schema/data-integrity-report-1.0.json

OC-6: StakeholderFeedbackEvent (learning loop) [Informative, optional]

- **Producer(s):** DR portal; G3 (aggregation)
- **Topic/Path:** sec.dr.recovery.feedback
- **Schema/Format:** StakeholderFeedbackEvent@1.0
(label={helpful|neutral|harmful}, note, artifact_id)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-feedback-id
- **Idempotency-Key:** sha256(feedback_id, artifact_id)
- **Ack/Nack:** feedback_id assigned; retry/backoff
- **Side-Effects:** enqueue for governance-reviewed updates to runbooks
- **Observability:** trace_id, mission_id
- **Retention/TTL:** 1 year

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When feedback workflow is enabled

schema_id=StakeholderFeedbackEvent@1.0 |

json_schema_uri=uri://schema/stakeholder-feedback-1.0.json

State machine (concise) [Informative]

states = { idle, evaluating_eligibility, restoring_data, redeploying_services, warming_up, verifying, switching_traffic, monitoring_post_cutover, contestation_workflow, backout, failed, closed }

transition(idle -> evaluating_eligibility) when runbook + DR state received

transition(evaluating_eligibility -> restoring_data) when meets_rpo=true AND
dr_ready=true

transition(restoring_data -> redeploying_services) when restore_verified=true

transition(redeploying_services -> warming_up) when deploy_success=true

transition(warming_up -> verifying) when health_checks_init=true

transition(verifying -> switching_traffic) when verification_pass=true AND

change_window=open

transition(switching_traffic -> monitoring_post_cutover) when cutover_started=true

transition(monitors_post_cutover -> closed) when acceptance_criteria_met=true
within window

transition(verifying -> backout) when verification_pass=false AND

backout_available=true

transition(* -> contestation_workflow) on RecoveryDispute opened
 transition(* -> failed) on hard_error OR timeout_exceeded
 timeout(restoring_data, rto_target_minutes) -> backout or failed by policy
 idempotency_key(OC-1) = sha256(plan_id, plan_version, execution_id)
 idempotency_key(OC-2) = sha256(execution_id, cutover_version)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 RecoveryActionOutcome	Required	Always	Core DR visibility & audit
OC-2 CutoverCompleted	Conditionally Required	Any traffic switch or production cutover	Change control and SLA closure
OC-3 RecoveryDispute	Optional	Contestability enabled	Governance & explainability
OC-4 DRRunbookDeviationEvent	Optional	Drift detection enabled	Runbook quality and change mgmt
OC-5 DataIntegrityReport	Conditionally Required	must_verify_integrity:true	Data assurance and risk reduction
OC-6 StakeholderFeedbackEvent	Optional	Feedback workflow enabled	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- policy_refs: CP-2, CP-9, CP-10 (+ internal DR standards)
- **HITL required:** customer-facing cutover; schema-altering deployments; dependencies degraded; integrity uncertain
- Automatic HITL triggers: model_confidence < theta_low; snapshot_integrity != verified; dependency_health < threshold; legal_hold=true
- Manual outside agent: permanent topology reconfiguration; regulatory notifications

SLOs and KPIs [Informative]

- RecoveryStartLatency_p95 <= 3 minutes from command
- RTO_AchievementRate_30d >= 95 percent
- RPO_AchievementRate_30d >= 98 percent
- IntegrityVerificationPassRate_30d >= 99 percent
- BackoutRate_30d <= 3 percent

Outputs index [Informative]

[OC-1 RecoveryActionOutcome], [OC-2 CutoverCompleted], [OC-3 RecoveryDispute], [OC-4 DRRunbookDeviationEvent], [OC-5 DataIntegrityReport], [OC-6 StakeholderFeedbackEvent]

Technical Implementation Details (G3) [Informative]

Model and training profile [Informative]

model_id=recovery-orch-planner; temperature=0.05; max_tokens_out=700
 prompt_pack_id=dr-orch-v1 (prechecks, ordering, verification, backout rubric)
 RAG: sources={runbook repo, backup catalog index, IaC/CD docs, traffic-manager APIs, DR drill logs}; max_docs=12; min_similarity=0.8; citations required
 fine_tuning/adapters: optional on anonymized drill outcomes; eval on plan safety and SLA attainment
 guardrails: enforce constraints and approvals; deny off-runbook actions; use secrets manager for credentials

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal (eligibility, steps, evidence_refs, outcomes), ttl=365d

semantic_memory: namespaces=["runbooks","backups","infra","drills"];
embeddings=text-embedding-sec-v1; k=12
durable_state_store: event-sourced; snapshot on step boundaries
consistency: at-least-once (OC-1); at-least-once (OC-2)
idempotency: per Output Contracts

Decision and routing logic [Informative]

meets_rpo = snapshot_age_minutes <= rpo_target_minutes
meets_rto = estimated_total_minutes <= rto_target_minutes
eligibility_score = 0.4 $dr_site_readiness$ + 0.3(1 - replication_lag_norm) +
0.2 $dependency_health$ + 0.1runbook_freshness
cutover_allowed = meets_rpo AND verification_pass AND change_window=open AND
(HITL_approved OR low_risk_service=true)

where:

replication_lag_norm = min(1, lag_seconds / (rpo_target_minutes*60))
runbook_freshness = clamp(1 - days_since_last_test / 30, 0, 1)

Model Risk Management [Informative]

continuous_validation: daily simulations with sandboxes and chaos-injection on
dependencies
thresholds: plan_safety_eval >= 99.0 percent → else auto_HITL
red_team_cycle: monthly DR adversarial drills (corrupted snapshot, partial region
outage)
rollback_policy: if RTO_AchievementRate_7d < 90 percent → revert model_id to last
known-good; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: plan_id, why-eligible, prechecks passed, integrity proofs,
verification evidence, SLA computations
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL with stable field order; retention per legal_hold and
classification

Incident Response & DR Integration [Informative]

emit OC-1 to DR/IR bus; integrate with change management; attach outcomes to
tickets/cases
on cutover: emit OC-2 and update SLAs

Integrity and Verification [Informative]

when must_verify_integrity:true → run integrity suite; emit OC-5; block cutover on fail

Stakeholder Feedback Loop [Informative]

collect StakeholderFeedbackEvent (OC-6); governance-reviewed updates to runbooks; never auto-train on regulated evidence

Data Sovereignty and Legal Hold [Informative]

respect region constraints for restore and traffic; legal_hold=true → extend TTLs and freeze destructive actions

Interfaces (links only) [Informative]

Consumes: Recovery Plans; DR State

Produces: OC-1 RecoveryActionOutcome; OC-2 CutoverCompleted; optional OC-3..OC-6

Safety and abuse prevention [Informative]

kill_switch on integrity failure or provenance anomaly; canary traffic by default; rate limit infra changes; circuit breaker on dependency degradation

Testing and validation [Informative]

contract tests for OCs; replay past incidents/drills; chaos tests for snapshot corruption and DNS propagation delays; drift checks on runbooks

Deployment and lifecycle [Informative]

HPA on job queue; canary rollout of planner; SBOM and SLSA attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-34 Rev. 1; NIST SP 800-53 Rev. 5 (CP family); NIST SP 800-61 Rev. 2; NIST SP 800-137; ISO/IEC 22301; MITRE D3FEND

MCP-Native Protocol Specification (G3) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** Recovery Plans (REST/Git JSON/YAML); DR State (REST/Stream)
- **Native Protocol(s) Produced:** RecoveryActionOutcome (Kafka/AMQP/REST); CutoverCompleted (Kafka/AMQP)

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- **MCP Context Fields:**
 - **Required:** mission_id; role="RecoveryOrchestrationAgent"; intent="recover"; constraints including rto_target_minutes, rpo_target_minutes, change_window, must_verify_integrity; provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** policy_refs (CP-2, CP-9, CP-10); classification; decision_basis (evidence_refs, confidence, explanation_ref); legal_hold
- **Enforcement Note:** Must verify integrity and eligibility before cutover; must honor RTO/RPO and change_window; must record evidence_refs for each step.
- **Versioning and compatibility; producers/consumers registry:** authoritative in the schema registry (see Schema Capsules).
- **Example payloads:** authoritative native + MCP-wrapped examples as provided above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url for downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

G4. Forensic Analysis Agent

Agent Blueprint [Informative]

Purpose: Analyze compromised endpoints, servers, and cloud workloads by examining disk and memory images plus relevant logs; produce **RCAFindings** and an **EvidenceManifest** with chain-of-custody.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Forensic Disk Image** (AFF4/E01/RAW via object storage): acquisition metadata (format, uri, size_bytes, sha256, acquired_at/by, write_blocker, signed_manifest_uri), asset tuple (asset_id, hostname, ip, platform).
- **Volatile Memory Image** (LiME/WinPMem/AFF4 via object storage): format, uri, size_bytes, sha256, acquired_at/by, symbol profile.
- **Log Bundle** (EVTX/Sysmon/Syslog/CloudTrail/CloudLogs via HTTPS/object storage): bundle uri, time range, counts, file list with hashes, sample events.

Model training / knowledge (what the LLM relies on):

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- DFIR rubric: triage order, artifact priority (MFT, USN, LNK, ShimCache, Prefetch, SRUM, Registry; for Linux: bash history, auth logs, journalctl, auditd), memory analysis playbooks (malproc, DLL injection, hooks, creds-in-mem), cloud timeline fusion.
- RAG sources: tool docs (Volatility, Rekall, Plaso/log2timeline, KAPE, Autopsy, CloudTrail parsers), ATT&CK and D3FEND matrices, internal case library, chain-of-custody templates. No customer data or raw evidence in training; fetch via evidence_refs only.
- Guardrails: respect constraints (offline_analysis, pii_minimize, no_cloud_uploads); never write to evidence stores except via append-only manifests; cryptographic verification required before use.

Decisions it makes (deterministic + model-assisted):

- **Evidence integrity gate:** verify hashes and signed manifests; quarantine any mismatch and emit IntegrityAnomalyEvent.
- **Timeline fusion:** correlate disk, memory, and logs into a unified sequence with confidence scores.
- **Root-cause hypothesis:** infer initial access vector, persistence, lateral movement, impact; map to ATT&CK techniques; compute attribution confidence.
- **Data impact estimate:** identify potentially accessed or exfiltrated data sets; estimate exfil_confidence_score.

Routing / where outputs go:

- **RCAFindings** → IR case management and reporting bus (Kafka/AMQP/REST); includes ATT&CK mapping, attack path, indicators, impacted datasets, recommended eradication steps.
- **EvidenceManifest** → object/REST store; append-only chain-of-custody with hashes, provenance, retention and legal_hold flags.

Automation scope vs. manual/HITL:

- Fully automated: hash verification, artifact extraction and parsing, timeline fusion, IOC extraction, initial ATT&CK mapping, draft RCA and indicators.
- **HITL required:** final attribution conclusions; public/regulatory-facing impact statements; any low-confidence or conflicting-evidence scenarios; PII-heavy evidence review.

- Manual outside agent: legal strategy, customer notifications, law-enforcement coordination, executive briefings.

Security Domain: Incident Response & Digital Forensics (IR/DFIR)

Inputs (native protocols consumed) [Informative]

1. **Forensic Disk Image — AFF4 / E01 / RAW (S3/HTTPS)** — immutable disk evidence with signed acquisition manifest.
2. **Volatile Memory Image — LiME / WinPMem / AFF4 (S3/HTTPS)** — memory evidence with symbol profile.
3. **Log Bundle — EVTX/Sysmon/Syslog/CloudTrail (HTTPS/Object storage)** — time-scoped logs for timeline fusion.

Example: Consumed Protocol — Forensic Disk Image [Informative]

Native payload

```
{
  "case_id": "INC-45877",
  "asset": {"asset_id": "srv-001", "hostname": "srv-001", "ip": "10.2.14.5", "platform": "linux"},
  "image": {
    "format": "AFF4",
    "uri": "s3://ir-evidence/inc-45877/srv-001/disk.aff4",
    "size_bytes": 53687091200,
    "sha256": "2e8c1b3f2a7f1a0f7d0c8c9e3f4b5a6c7d8e9f0a1b2c3d4e5f6a7b8c9d0e1f2a",
    "acquired_at": "2025-08-15T10:09:30Z",
    "acquired_by": "acq-agent-linux@1.4.2",
    "write_blocker": "nvme-wb-003",
    "signed_manifest_uri": "s3://ir-evidence/inc-45877/srv-001/disk.manifest.json"
  },
  "notes": "Hot acquisition after host isolation; nvme0n1 + LVM"
```

```
}
```

MCP-wrapped payload

```
{
```

```
"mcp_context": {  
  "mcp_version": "0.9",  
  "mission_id": "uuid-g4-forensics-1111-2222-3333-4444",  
  "thread_id": "uuid-case-INC-45877-srv-001-disk",  
  "task_id": "uuid-aa11-bb22-cc33-dd44",  
  "role": "ForensicAnalysisAgent",  
  "intent": "analyze",  
  "policy_refs": ["IR-4", "IR-5", "AU-9", "AU-11"],  
  "legal_hold": true,  
  "decision_basis": {  
    "evidence_refs": [  
      "s3://ir-evidence/inc-45877/srv-001/disk.aff4",  
      "s3://ir-evidence/inc-45877/srv-001/disk.manifest.json"  
    ],  
    "confidence": 0.99,  
    "explanation_ref": "uri://kb/dfir/workflows/disk-triage-mft-lnk-webhist"  
  },  
  "provenance": {  
    "producer_spiffe": "spiffe://enterprise/ir/forensic-analysis-agent",  
    "signing_kid": "kid-forensic-g4-01",  
    "attestation_ref": "uri://slsa/attestations/forensic-analysis@sha256:aff4disk01"  
  },  
  "classification": "C3",  
  "constraints": ["offline_analysis:true"]  
}
```

```
},  
  "native_payload": { ... }  
}
```

Example: Consumed Protocol — Volatile Memory Image [Informative]

Native payload

```
{  
  "case_id": "INC-45877",  
  "asset": {"asset_id": "srv-001", "platform": "linux", "kernel": "5.15.0-1058-aws"},  
  "memory_image": {  
    "format": "AFF4",  
    "uri": "s3://ir-evidence/inc-45877/srv-001/memory.aff4",  
    "size_bytes": 17179869184,  
    "sha256":  
"ab9ef2c6d147c0d4f9e2c0d5e1f2c3a4b5c6d7e8f90123456789abcdef012345",  
    "acquired_at": "2025-08-15T10:12:05Z",  
    "acquired_by": "LiME@1.9.1",  
    "symbol_profile": {"volatility": "linux_5_15_aws_x64.json"}  
  },  
  "notes": "Capture taken prior to service restart"  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-g4-forensics-1111-2222-3333-4444",  
    "thread_id": "uuid-case-INC-45877-srv-001-mem",  
    "task_id": "uuid-ee11-ff22-0011-2233",
```

```

"role": "ForensicAnalysisAgent",
"intent": "analyze",
"policy_refs": ["IR-4", "IR-5", "AU-9"],
"legal_hold": true,
"decision_basis": {
  "evidence_refs": ["s3://ir-evidence/inc-45877/srv-001/memory.aff4"],
  "confidence": 0.98,
  "explanation_ref": "uri://kb/dfir/workflows/memory-analysis#malproc-hooks"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/ir/forensic-analysis-agent",
  "signing_kid": "kid-forensic-g4-02",
  "attestation_ref": "uri://slsa/attestations/forensic-analysis@sha256:aff4mem02"
},
"classification": "C3",
"constraints": ["offline_analysis:true"]
},
"native_payload": { ... }
}

```

Example: Consumed Protocol — Log Bundle [Informative]

Native payload

```

{
  "case_id": "INC-45877",
  "bundle_uri": "s3://ir-evidence/inc-45877/srv-001/logs.tar.zst",
  "index": {
    "time_range": {"start": "2025-08-15T09:30:00Z", "end": "2025-08-15T10:30:00Z"},
    "counts": {"evtx": 18432, "sysmon": 9211, "syslog": 5607, "cloudtrail": 337}
  }
}

```

```

},
"files": [
  {"path": "windows/security.evtx", "sha256": "3b...71", "format": "EVTX"},
  {"path": "sysmon.ndjson.zst", "sha256": "7a...c2", "format": "JSONL"},
  {"path": "linux/auth.log", "sha256": "5f...9d", "format": "SYSLOG"},
  {"path": "aws/cloudtrail/2025/08/15/10.json.gz", "sha256": "1e...aa", "format": "JSON"}
],
"sample_event": {
  "sysmon": {
    "UtcTime": "2025-08-15T10:00:12Z",
    "EventID": 1,
    "Image": "/usr/bin/passwd",
    "User": "jdoe",
    "ParentImage": "/usr/bin/sudo",
    "CommandLine": "passwd root"
  }
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-g4-forensics-1111-2222-3333-4444",
    "thread_id": "uuid-case-INC-45877-logs",
    "task_id": "uuid-1122-3344-5566-7788",
    "role": "ForensicAnalysisAgent",
    "intent": "analyze",
  }
}

```

```

"policy_refs": ["AU-6", "AU-9", "AU-11", "IR-5"],
"legal_hold": true,
"decision_basis": {
  "evidence_refs": ["s3://ir-evidence/inc-45877/srv-001/logs.tar.zst"],
  "confidence": 0.97,
  "explanation_ref": "uri://kb/dfir/workflows/timeline-fusion"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/ir/forensic-analysis-agent",
  "signing_kid": "kid-forensic-g4-03",
  "attestation_ref": "uri://slsa/attestations/forensic-analysis@sha256:logs03"
},
"classification": "C3",
"constraints": ["pii_minimize:true"]
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **RCAFindings** (REST/Kafka/AMQP): root cause indicators, attack path, ATT&CK mapping, impacted data, eradication recommendations.
- **EvidenceManifest** (JSON/CSV via REST/object storage): hashes, provenance, chain-of-custody entries, retention schedule.

MCP context (required) [Informative]

mission_id; role="ForensicAnalysisAgent"; intent="analyze"; policy_refs (IR-4, IR-5, AU-6, AU-9, AU-11); legal_hold=true; provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

classification (typically C3); decision_basis (evidence_refs, confidence, explanation_ref); constraints (offline_analysis:true, pii_minimize:true, no_cloud_uploads:true|false)

Enforcement note [Informative]

Consumers MUST verify: evidence hashes match manifests; legal_hold=true is preserved; classification=C3 enforced; any pii_minimize constraint is honored in derived artifacts.

NIST SP 800-160v2 linkage [Informative]

Respond & Recover — evidence-driven assurance with secure provenance; aligns to NIST SP 800-61 and SP 800-86 forensic processes.

Automation feasibility [Informative]

Moderate–High: artifact parsing, timeline fusion, IOC extraction are automatable; human review for final attribution and sensitive disclosures.

Output Contracts (merged) [Informative]

(OC-1/OC-2 are primary. OC-3..OC-6 support enterprise extensions.)

OC-1: RCAFindings (root cause and attack path) [Informative]

- **Producer(s):** G4
- **Topic/Path:** sec.ir.forensics.rca (Kafka/AMQP) or POST /forensics/rca
- **Schema/Format:** RCAFindings@1.1 (case_id, asset_set, attack_path[], attck_techniques[], initial_access, persistence, lateral_movement, iocs[], impacted_data[], recommendations[], confidence)
- **Classification:** C3
- **Delivery:** at-least-once
- **Ordering:** per-case_id
- **Idempotency-Key:** sha256(case_id, rca_version)
- **Ack/Nack:** broker ACK or HTTP 201; schema reject → NACK and retry/backoff
- **Timeouts/Retry:** ack<=20s; exp-backoff<=5x
- **Side-Effects:** attach to case; trigger eradication tasks in SOAR via links
- **HITL Token:** required if confidence < theta_low or impacted_data contains regulated PII
- **Observability:** trace_id, mission_id, policy_refs, evidence_refs, decision_basis.*, classification_label, provenance.attestation

- **Retention/TTL:** 7 years (legal_hold)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=RCAFindings@1.1 | json_schema_uri=uri://schema/rca-findings-1.1.json | sha256= | producers=G4 | consumers=IR-Case-01, G1, G2, Audit-Journal-01 | accepts=1.0–1.1 (1.0 EOL 2027-01-01)

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: EvidenceManifest (chain-of-custody) [Informative]

- **Producer(s):** G4
- **Location:** s3://ir-evidence/{case_id}/manifest/{manifest_id}.json (or CSV variant)
- **Schema/Format:** EvidenceManifest@1.2 (entries[], sha256, signed_by, acquisition, transfers[], analysis_tools[], retention, legal_hold, redaction_policy)
- **Classification:** C3
- **Delivery:** exactly-once write; reference distributed via sec.ir.forensics.manifest
- **Ordering:** per-case_id
- **Idempotency-Key:** sha256(case_id, manifest_id)
- **Ack/Nack:** 201 Created; NACK on signature failure; retry/backoff
- **Side-Effects:** append immutable audit journal record; lock retention clocks
- **HITL Token:** required to release redacted copies when pii_minimize=true
- **Observability:** trace_id, mission_id, provenance.attestation
- **Retention/TTL:** per AU-11 or legal_hold override (>= 7 years typical)

Schema Capsule (OC-2) [Normative]

Requirement Level: Required

Condition: Always

schema_id=EvidenceManifest@1.2 | json_schema_uri=uri://schema/evidence-manifest-1.2.json | sha256= | producers=G4 | consumers=Audit-Journal-01, Legal-01, IR-Case-01 | accepts=1.1–1.2 (1.1 EOL 2026-12-31)

OC-3: ForensicDispute (contestability workflow) [Informative, optional]

- **Producer(s):** G4, IR-Portal-01, Legal-01
- **Topic/Path:** sec.ir.forensics.contestation
- **Schema/Format:** ForensicDispute@1.0 (case_id, dispute_id, rationale_url, requested_action)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-case_id
- **Idempotency-Key:** sha256(case_id, dispute_id)
- **Ack/Nack:** case_id link <= 30 s; retry/backoff
- **Side-Effects:** pause publication of final RCA until resolved

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability workflow is enabled

schema_id=ForensicDispute@1.0 | json_schema_uri=uri://schema/forensic-dispute-1.0.json

OC-4: IntegrityAnomalyEvent (hash/provenance anomaly) [Informative, optional]

- **Producer(s):** G4
- **Topic/Path:** sec.ir.forensics.integrity
- **Schema/Format:** IntegrityAnomalyEvent@1.0 (artifact_uri, expected_hash, observed_hash, anomaly_type, action_taken)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-artifact
- **Idempotency-Key:** sha256(artifact_uri, anomaly_type)
- **Ack/Nack:** broker ACK; retry/backoff
- **Side-Effects:** quarantine artifact; notify chain-of-custody owner

Schema Capsule (OC-4) [Normative]

Requirement Level: Conditionally Required

Condition: When any evidence hash or signature verification fails

schema_id=IntegrityAnomalyEvent@1.0 | json_schema_uri=uri://schema/integrity-anomaly-1.0.json

OC-5: PIIAnonymizationReport (privacy handling) [Informative, optional]

- **Producer(s):** G4
- **Topic/Path:** sec.ir.forensics.pii
- **Schema/Format:** PIIAnonymizationReport@1.0 (artifact_id, pii_found, redaction_actions[], residual_risk)
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per-artifact
- **Idempotency-Key:** sha256(artifact_id, report_version)
- **Ack/Nack:** broker ACK; retry/backoff

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When constraint includes pii_minimize:true

schema_id=PIIAnonymizationReport@1.0 | json_schema_uri=uri://schema/pii-anonymization-report-1.0.json

OC-6: ToolArtifactIndex (tool outputs registry) [Informative, optional]

- **Producer(s):** G4
- **Topic/Path:** sec.ir.forensics.tools.index
- **Schema/Format:** ToolArtifactIndex@1.0 (tool_name, version, parameters_hash, outputs[], evidence_refs)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-tool-run
- **Idempotency-Key:** sha256(tool_name, parameters_hash)
- **Ack/Nack:** broker ACK; retry/backoff

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When tool output cataloging is enabled

schema_id=ToolArtifactIndex@1.0 | json_schema_uri=uri://schema/tool-artifact-index-1.0.json

State machine (concise) [Informative]

states = { idle, verifying_evidence, parsing_images, parsing_memory, parsing_logs, timeline_fusion, hypothesis_generation, attribution_review, reporting, contestation_workflow, failed, closed }

transition(idle -> verifying_evidence) when first evidence_ref arrives

transition(verifying_evidence -> parsing_images) when hashes and signatures verified

transition(parsing_images -> parsing_memory) when disk triage complete

transition(parsing_memory -> parsing_logs) when memory artifacts extracted

transition(parsing_logs -> timeline_fusion) when log bundle parsed

transition(timeline_fusion -> hypothesis_generation) when unified timeline built

transition(hypothesis_generation -> attribution_review) when RCA draft ready

transition(attribution_review -> reporting) when HITL approval recorded

transition(* -> contestation_workflow) when ForensicDispute opened

transition(* -> failed) on verification failure, schema error, or timeout

timeout(parsing_images, 30m) -> failed; retry <= 2 with exp backoff

idempotency_key(OC-1) = sha256(case_id, rca_version)

idempotency_key(OC-2) = sha256(case_id, manifest_id)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 RCAFindings	Required	Always	IR decision support and eradication
OC-2 EvidenceManifest	Required	Always	Chain-of-custody and compliance
OC-3 ForensicDispute	Optional	Contestability enabled	Governance and explainability

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-4 IntegrityAnomalyEvent	Conditionally Required	Any hash/signature/provenance anomaly detected	Evidence integrity and risk control
OC-5 PIIAnonymizationReport	Conditionally Required	Constraint pii_minimize:true is in effect	Privacy compliance and scoping
OC-6 ToolArtifactIndex	Optional	Tool output cataloging enabled	Reproducibility and auditability

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: IR-4, IR-5, AU-6, AU-9, AU-11 (+ internal DFIR standards)
- **HITL required:** final attribution and impacted-data assertions; low-confidence hypotheses; any public/regulatory deliverable; high-profile executives' devices
- Automatic HITL triggers: model_confidence < theta_low;
integrity_anomaly_detected=true; stakeholder_disagreement_score >= 0.5;
legal_hold=true (default)

SLOs and KPIs [Informative]

- EvidenceVerificationLatency_p95 <= 5 minutes per artifact
- RCA_DraftLatency_p95 <= 60 minutes from last evidence arrival
- EvidenceChainCompleteness >= 99.9 percent entries present and signed
- FalseAttributionRate_30d <= 1 percent
- IntegrityAnomalyDetectionRate >= 99.99 percent of tampered artifacts

Outputs index [Informative]

[OC-1 RCAFindings], [OC-2 EvidenceManifest], [OC-3 ForensicDispute], [OC-4 IntegrityAnomalyEvent], [OC-5 PIIAnonymizationReport], [OC-6 ToolArtifactIndex]

Technical Implementation Details (G4) [Informative]

Model and training profile [Informative]

model_id=forensics-analyst; temperature=0.05; max_tokens_out=900
prompt_pack_id=dfir-analysis-v1 (artifact triage rubric, chain-of-custody rules, ATT&CK mapping)
RAG: sources={tool docs, internal case library, ATT&CK, D3FEND, parser schemas};
max_docs=12; min_similarity=0.8; citations required
fine_tuning/adapters: optional on anonymized case summaries; eval on precision/recall for IOC extraction and mapping correctness
guardrails: enforce offline_analysis and pii_minimize; deny external uploads if
no_cloud_uploads:true

Memory and state [Informative]

working_memory.max_tokens=6k; eviction=recency_then_importance
episodic_memory: per mission_id journal (verifications, extractions, timeline nodes, hypotheses), ttl=365d
semantic_memory: namespaces=["artifacts","timelines","attck","cases"];
embeddings=text-embedding-sec-v1; k=12
durable_state_store: append-only event log with signed snapshots; snapshot at stage boundaries
consistency: at-least-once for all outputs; exactly-once write for manifest updates
idempotency: per Output Contracts

Decision and routing logic [Informative]

$timeline_confidence = 0.5log_coverage + 0.3artifact_quality + 0.2time_sync_score$
 $attribution_confidence = 0.4evidence_consistency + 0.3technique_match + 0.2rarity_weight + 0.1analyst_feedback_score$
 $exfil_confidence_score = 0.5data_access_evidence + 0.3egress_signal + 0.2dwell_time_weight$

where each term is normalized to [0..1]; rarity_weight favors uncommon TTPs;
 $dwell_time_weight = \min(1, hours_present / 24)$

Model Risk Management [Informative]

continuous_validation: daily golden-cases + adversarial (tampered timestamps, truncated images)

thresholds: eval_pass_rate >= 99.0 percent → else auto_HITL
red_team_cycle: monthly integrity evasion tests (hash collisions, path tampering, selective redaction)
rollback_policy: if FalseAttributionRate_7d > 2 percent → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who/what/why; evidence_refs with hashes; ATT&CK technique list; uncertainty notes; redactions applied
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL; stable field order; retention per AU-11 and legal_hold

IR/SOAR Integration [Informative]

emit RCAFindings to IR bus; auto-create eradication task stubs; attach EvidenceManifest link; notify containment and recovery agents of IOCs and eradication preconditions

Privacy and Data Handling [Informative]

if pii_minimize:true → anonymize fields in derived artifacts; emit PIIAnonymizationReport (OC-5); never store raw secrets in outputs

Data Sovereignty and Legal Hold [Informative]

default legal_hold=true; keep artifacts in region; prohibit cross-region transfers unless policy allows

Interfaces (links only) [Informative]

Consumes: Disk Image; Memory Image; Log Bundle
Produces: OC-1 RCAFindings; OC-2 EvidenceManifest; optional OC-3..OC-6

Safety and abuse prevention [Informative]

kill_switch if provenance invalid or hash mismatches; quarantine anomalies; throttle parsing on oversized bundles; sandbox tool execution

Testing and validation [Informative]

contract tests for OCs; replay historical cases; checksum and signature tests; clock-skew simulation; parser fuzzing

Deployment and lifecycle [Informative]

HPA on parsing queue; canary model rollout; SBOM and SLSA attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-61 Rev. 2; NIST SP 800-86; NIST SP 800-53 Rev. 5 (IR, AU); NIST SP 800-101 Rev. 1; NIST SP 800-92; MITRE ATT&CK and D3FEND; ISO/IEC 27037; SLSA; SPIFFE/SPIRE

MCP-Native Protocol Specification (G4) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** Forensic Disk Image (S3/HTTPS); Volatile Memory Image (S3/HTTPS); Log Bundle (HTTPS/Object)
- **Native Protocol(s) Produced:** RCAFindings (REST/Kafka/AMQP); EvidenceManifest (REST/Object)
- **MCP Context Fields:**
 - **Required:** mission_id; role="ForensicAnalysisAgent"; intent="analyze"; policy_refs (IR-4, IR-5, AU-6, AU-9, AU-11); legal_hold=true; provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** classification (C3); decision_basis (evidence_refs, confidence, explanation_ref); constraints (offline_analysis, pii_minimize, no_cloud_uploads)
- **Enforcement Note:** Consumers MUST validate evidence hashes, signatures, and legal_hold propagation; PEPs MUST block distribution of C3 artifacts to non-cleared principals; pii_minimize enforcement on derived artifacts.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry (see Schema Capsules).
- **Example payloads:** authoritative native + MCP-wrapped examples included above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

G5. RCA Analysis Agent

Agent Blueprint [Informative]

Purpose: Aggregate forensic findings and incident timelines, synthesize a defensible **RootCauseReport**, and produce a concrete **RemediationPlan** linked to lessons learned.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **RCAFindings** (from Forensic Analysis Agent): attack graph, artifacts, impacted scope, confidence, analyst notes.
- **Incident Timelines** (from incident management): ordered events (detection, containment, recovery), severity, category, ownership.

Model training / knowledge (what the LLM relies on):

- RCA rubric: causality tests (temporal precedence, mechanism plausibility, counterfactuals), ATT&CK mapping completeness, evidence-to-claim traceability.
- RAG sources: internal lessons-learned KB, prior RCAs, control catalogs (NIST 800-53/CSF), change records, baselines, runbooks. Do not train on regulated evidence; fetch via `evidence_refs`.
- Guardrails: **must include** `decision_basis` with both `evidence_refs` and `explanation_ref` (lessons learned); redact PII when constraints include `redact_pii:true`; `publish_to_kb` gated by classification and approvals.

Decisions it makes (deterministic + model-assisted):

- **Causal synthesis:** select primary and contributing causes; compute `causal_confidence` and alternative-hypothesis residuals.
- **Control linkage:** map causes to failed/absent controls and program requirements (e.g., IR, AC, CM, CP families).
- **Remediation planning:** generate objectives, tasks, owners, acceptance criteria, and success metrics; propose `ChangeIntent(s)` for baselines/patches.
- **Publication routing:** determine if **RootCauseReport** is public-internal (C2) vs restricted (C3), and whether to open a KB PR.

Routing / where outputs go:

- **RootCauseReport** → IR case system and reporting bus; optional PR to knowledge base repo.
- **RemediationPlan** → change/baseline/patch queues; open ChangeIntent items and link to tracking systems.

Automation scope vs. manual/HITL:

- Fully automated: aggregation, correlation, causal draft, control mapping, initial remediation plan, KB PR draft.
- **HITL required:** final causal assertions and language for externally shared reports; remediation that alters privileged policies or CrownJewels; conflicting evidence cases.
- Manual outside agent: regulatory notifications, disciplinary HR actions, cross-org accountability decisions.

Security Domain: Incident Response & Digital Forensics (IR/DFIR)

Inputs (native protocols consumed) [Informative]

1. **RCAFindings (REST/Kafka/AMQP JSON)** — synthesized forensic findings.
2. **Incident Timelines (Incident Mgmt REST/JSON)** — chronological incident events.

Example: Consumed Protocol — RCAFindings [Informative]

Native payload

```
{
  "case_id": "INC-45877",
  "finding_id": "RCAF-00041",
  "artifacts": [
    {"type": "file", "path": "/usr/bin/passwd", "hash_sha256": "f1a2..."},
    {"type": "proc", "name": "sudo", "ppid": 1123, "cmd": "sudo passwd root"},
    {"type": "log", "source": "sysmon", "event_id": 1, "utc": "2025-08-15T10:00:12Z"}
  ],
  "attack_graph": {
```

```

    "nodes": ["InitialAccess:ValidAccounts", "Execution:CommandLine",
"PrivilegeEscalation:Sudo"],
    "edges": [["ValidAccounts","CommandLine"], ["CommandLine","Sudo"]]
  },
  "impact": {"scope": "host", "data_exfil": false},
  "confidence": 0.92,
  "analyst_notes": "Evidence supports credential misuse followed by passwd invocation."
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-g5-rca-1111-2222-3333-4444",
    "thread_id": "uuid-case-INC-45877-rca",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "RCAAnalysisAgent",
    "intent": "analyze",
    "policy_refs": ["IR-4","IR-5"],
    "decision_basis": {
      "evidence_refs": ["uri://rca/findings/RCAF-00041"],
      "confidence": 0.92,
      "explanation_ref": "uri://kb/lessons_learned/valid-accounts-hardening"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/ir/rca-analysis-agent",
      "signing_kid": "kid-rca-g5-01",
      "attestation_ref": "uri://slsa/attestations/rca-analysis@sha256:rca01"
    }
  }
}

```

```

    },
    "classification": "C2",
    "legal_hold": true
  },
  "native_payload": { ... }
}

```

Example: Consumed Protocol — Incident Timelines [Informative]

Native payload

```

{
  "incident_id": "INC-45877",
  "timeline": [
    {"ts": "2025-08-15T09:58:40Z", "type": "compromise_observed"},
    {"ts": "2025-08-15T10:00:12Z", "type": "detection", "ref": "DET-2025-08-15-7711"},
    {"ts": "2025-08-15T10:01:23Z", "type": "containment", "action": "isolate_host", "target": "srv-001"},
    {"ts": "2025-08-15T10:17:05Z", "type": "restore", "service": "payments-api"}
  ],
  "severity": "High",
  "category": "PrivilegeEscalation",
  "owner_group": "sec.ir"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-g5-rca-1111-2222-3333-4444",
    "thread_id": "uuid-timeline-INC-45877",

```

```

"task_id": "uuid-ee11-ff22-0011-2233",
"role": "RCAAnalysisAgent",
"intent": "analyze",
"policy_refs": ["IR-4", "PM-5"],
"decision_basis": {
  "evidence_refs": ["uri://incident/api/incidents/INC-45877/timeline"],
  "confidence": 0.95,
  "explanation_ref": "uri://kb/lessons_learned/priv-esc-sudo-monitoring"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/ir/rca-analysis-agent",
  "signing_kid": "kid-timeline-g5-02",
  "attestation_ref": "uri://slsa/attestations/rca-analysis@sha256:timeline02"
},
"classification": "C2",
"legal_hold": true
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **RootCauseReport** (REST/JSON; optionally Git PR) with causal narrative, ATT&CK mapping, evidence citations, residual uncertainties, and lessons-learned link.
- **RemediationPlan** (REST/JSON) targeting change/baseline/patch queues; may spawn **ChangeIntent** items.

MCP context (required) [Informative]

mission_id; role="RCAAnalysisAgent"; intent="analyze"; **decision_basis** (must include evidence_refs **and** explanation_ref to lessons learned); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

policy_refs (IR-4, IR-5, CP-2, PM-5); classification (C2–C3); constraints (publish_to_kb:true, redact_pii:true); legal_hold (true if regulated evidence included)

Enforcement note [Informative]

Consumers MUST reject outputs lacking decision_basis.evidence_refs or decision_basis.explanation_ref; PEPs MUST enforce classification and redact_pii constraints before KB publication.

NIST SP 800-160v2 linkage [Informative]

Respond & Learn — causal analysis feeding architectural hardening; aligns with NIST SP 800-61 (post-incident) and 800-137 (ISCM feedback).

Automation feasibility [Informative]

High for correlation and synthesis; **HITL** for contested or external-facing conclusions.

Output Contracts (merged) [Informative]

(OC-1/OC-2 are primary. OC-3..OC-6 provide enterprise extensions.)

OC-1: RootCauseReport [Informative]

- **Producer(s):** G5
- **Topic/Path:** sec.ir.rca.report (REST: POST /rca/reports; optional Git PR to kb/lessons-learned/)
- **Schema/Format:** RootCauseReport@1.2 (case_id, primary_cause, contributing_causes[], causal_graph, attck_techniques[], evidence_refs[], explanation_ref, uncertainties[], lessons_learned_ref, recommendations_summary, causal_confidence)
- **Classification:** C2 (C3 if evidence excerpts present)
- **Delivery:** at-least-once
- **Ordering:** per-case_id
- **Idempotency-Key:** sha256(case_id, rca_version)
- **Ack/Nack:** 201 Created or PR #; schema reject → NACK; retry/backoff
- **Timeouts/Retry:** ack≤20s; exp-backoff≤5x
- **Side-Effects:** link to case; notify governance/policy owners; open follow-up items

- **HITL Token:** required if causal_confidence < theta_low or public/share outside security
- **Observability:** trace_id, mission_id, policy_refs, decision_basis.*, classification_label, provenance.attestation
- **Retention/TTL:** >= 7 years if legal_hold else 1 year

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=RootCauseReport@1.2 | json_schema_uri=uri://schema/root-cause-report-1.2.json | sha256= | producers=G5 | consumers=IR-Case-01, Audit-Journal-01, KB-Repo-01 | accepts=1.1–1.2 (1.1 EOL 2027-01-01)

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: RemediationPlan [Informative]

- **Producer(s):** G5
- **Topic/Path:** sec.ir.remediation.plan (REST: POST /rca/remediation)
- **Schema/Format:** RemediationPlan@1.1 (case_id, objectives[], tasks[], owners[], due_dates[], success_metrics[], blockers[], change_intents[], risk_reduction_estimate)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-case_id
- **Idempotency-Key:** sha256(case_id, plan_version)
- **Ack/Nack:** 201 Created; schema reject → NACK; retry/backoff
- **Timeouts/Retry:** ack<=20s; exp-backoff<=5x
- **Side-Effects:** enqueue changes to CMDB/baseline/patch queues; create tickets
- **HITL Token:** required for changes to CrownJewels or privileged policies
- **Observability:** trace_id, mission_id, policy_refs, decision_basis.*, provenance.attestation
- **Retention/TTL:** 1 year (longer if legal_hold)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When RCA identifies at least one actionable remediation objective
schema_id=RemediationPlan@1.1 | json_schema_uri=uri://schema/remediation-plan-1.1.json | sha256= | producers=G5 | consumers=Change-Queue-01, Baseline-Queue-01, Patch-Queue-01 | accepts=1.0–1.1

Conformance: Normative when condition is met.

OC-3: RCADispute (Explainability and Contestability) [Informative, optional]

- **Producer(s):** G5, IR-Portal-01, Legal/Compliance
- **Topic/Path:** sec.ir.rca.contestation
- **Schema/Format:** RCADispute@1.0 (case_id, dispute_id, rationale_url, requested_action)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-case_id
- **Idempotency-Key:** sha256(case_id, dispute_id)
- **Ack/Nack:** case_id link <= 30 s; retry/backoff

Schema Capsule (OC-3) [Normative]

Requirement Level: Optional

Condition: When contestability workflow is enabled
schema_id=RCADispute@1.0 | json_schema_uri=uri://schema/rca-dispute-1.0.json

OC-4: ControlDefectRecord (Program Feedback to GRC) [Informative, optional]

- **Producer(s):** G5
- **Topic/Path:** sec.program.control_defect
- **Schema/Format:** ControlDefectRecord@1.0 (control_id, defect_type, evidence_refs, severity, recommended_fix, owner)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-control_id
- **Idempotency-Key:** sha256(control_id, case_id)
- **Ack/Nack:** broker ACK; retry/backoff

Schema Capsule (OC-4) [Normative]

Requirement Level: Optional

Condition: When a control weakness is identified

schema_id=ControlDefectRecord@1.0 | json_schema_uri=uri://schema/control-defect-1.0.json

OC-5: ChangeIntent (Derived Change Requests) [Informative, optional]

- **Producer(s):** G5
- **Topic/Path:** sec.change.intent
- **Schema/Format:** ChangeIntent@1.0 (intent_id, category={policy|baseline|patch}, description, dependencies[], risk_score, target_assets[])
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-intent_id
- **Idempotency-Key:** sha256(intent_id)
- **Ack/Nack:** 201 Created; retry/backoff

Schema Capsule (OC-5) [Normative]

Requirement Level: Optional

Condition: When RemediationPlan spawns discrete change items

schema_id=ChangeIntent@1.0 | json_schema_uri=uri://schema/change-intent-1.0.json

OC-6: LessonsLearnedFeedbackEvent (Stakeholder Feedback Loop) [Informative, optional]

- **Producer(s):** Review portals; G5 (aggregation)
- **Topic/Path:** sec.ir.rca.feedback
- **Schema/Format:** LessonsLearnedFeedbackEvent@1.0 (review_id, artifact_id, label={helpful|neutral|harmful}, note)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-review_id
- **Idempotency-Key:** sha256(review_id, artifact_id)
- **Ack/Nack:** feedback_id assigned; retry/backoff

Schema Capsule (OC-6) [Normative]

Requirement Level: Optional

Condition: When feedback workflow is enabled

schema_id=LessonsLearnedFeedbackEvent@1.0 | json_schema_uri=uri://schema/ll-feedback-1.0.json

State machine (concise) [Informative]

states = { idle, aggregating_inputs, correlating, synthesizing_causality, drafting_rca, hitl_review, publishing_rca, planning_remediation, publishing_plan, monitoring_implementation, contestation_workflow, failed, closed }

transition(idle -> aggregating_inputs) when RCAFindings or Timeline arrives

transition(aggregating_inputs -> correlating) when both inputs present or timeout_satisfied

transition(correlating -> synthesizing_causality) when conflicts_resolved=true

transition(synthesizing_causality -> drafting_rca) when causal_confidence >= theta_min

transition(drafting_rca -> hitl_review) when classification in {C3} OR causal_confidence < theta_high

transition(hitl_review -> publishing_rca) when approval_recorded=true

transition(publishing_rca -> planning_remediation) when actionable_objectives >= 1

transition(planning_remediation -> publishing_plan) when plan_validated=true

transition(* -> contestation_workflow) when RCADispute opened

transition(* -> failed) on schema_error or evidence_incomplete

idempotency_key(OC-1) = sha256(case_id, rca_version)

idempotency_key(OC-2) = sha256(case_id, plan_version)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 RootCauseReport	Required	Always	Post-incident learning & governance
OC-2 RemediationPlan	Conditionally Required	At least one actionable remediation objective	Risk reduction & control hardening

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-3 RCADispute	Optional	Contestability enabled	Explainability & arbitration
OC-4 ControlDefectRecord	Optional	Control weakness identified	Program feedback into GRC
OC-5 ChangeIntent	Optional	Plan spawns concrete change items	Execution tracking for changes
OC-6 LessonsLearnedFeedbackEvent	Optional	Feedback workflow enabled	Continuous improvement

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: IR-4, IR-5, CP-2, PM-5 (+ internal governance)
- **HITL required:** external/public versions; causal_confidence < theta_high; disputes opened; CrownJewels implications
- Automatic HITL triggers: model_confidence < theta_low; stakeholder_disagreement_score >= 0.5; legal_hold=true with PII excerpts
- Manual outside agent: executive communications; regulatory submission language

SLOs and KPIs [Informative]

- RCADraftLatency_p95 <= 30 minutes after last input arrival
- DisputeResolution_p95 <= 5 business days
- RemediationPlanAcceptanceRate_30d >= 90 percent

- RiskReductionForecastAccuracy_60d >= 80 percent
- KBPublicationLeadTime_p95 <= 2 business days (when publish_to_kb:true)

Outputs index [Informative]

[OC-1 RootCauseReport], [OC-2 RemediationPlan], [OC-3 RCADispute], [OC-4 ControlDefectRecord], [OC-5 ChangeIntent], [OC-6 LessonsLearnedFeedbackEvent]

Technical Implementation Details (G5) [Informative]

Model and training profile [Informative]

model_id=rca-synthesizer; temperature=0.08; max_tokens_out=900
 prompt_pack_id=rca-rubric-v1 (causality tests, ATT&CK mapping, control linkage, report structure)
 RAG: sources={lessons-learned KB, prior RCAs, control catalogs, change/baseline logs}; max_docs=12; min_similarity=0.8; citations required
 fine_tuning/adapters: optional adapters on anonymized RCAs; eval on causal correctness and traceability
 guardrails: require decision_basis.evidence_refs and explanation_ref; enforce redact_pii; require approvals for publish_to_kb

Memory and state [Informative]

working_memory.max_tokens=4k; eviction=recency_then_importance
 episodic_memory: per mission_id journal (inputs, hypotheses, decisions, citations), ttl=365d
 semantic_memory: namespaces=["lessons","controls","rcas","changes"];
 embeddings=text-embedding-sec-v1; k=12
 durable_state_store: event-sourced; snapshot on publication
 consistency: at-least-once for OC-1/OC-2
 idempotency: per Output Contracts

Decision and routing logic [Informative]

causal_confidence = 0.35evidence_support + 0.25temporal_consistency +
 0.20technique_alignment + 0.10negatives_explained + 0.10analyst_feedback
 remediation_priority = 0.40business_impact + 0.30exploitability +
 0.20control_gap_severity + 0.10*exposure_breadth
 risk_reduction_estimate = baseline_risk - post_fix_risk

where each input component is normalized to [0..1]; baseline_risk derived from asset criticality, exposure, and recent incident frequency.

Model Risk Management [Informative]

continuous_validation: daily suite of golden RCAs + adversarial counterfactuals
thresholds: eval_pass_rate >= 99.0 percent → else auto_HITL
red_team_cycle: monthly tests for confirmation bias and over-claiming causality
rollback_policy: revert model_id if DisputeRate_14d > 10 percent or KB retractions occur

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: claim→evidence table with hashes and timestamps;
ATT&CK coverage; uncertainties and residual risk; lessons_learned links
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL with stable fields and citation pointers

Incident/Program Integration [Informative]

emit RootCauseReport to IR bus; post RemediationPlan to change/baseline/patch queues; open ControlDefectRecord in GRC when mapping indicates a program gap

Feedback & Learning [Informative]

collect LessonsLearnedFeedbackEvent; after governance review, update KB and prompt_pack; never auto-train on regulated evidence

Data Sovereignty and Legal Hold [Informative]

respect region for KB and ticketing; legal_hold=true → extended TTL and restricted publication

Interfaces (links only) [Informative]

Consumes: RCAFindings; Incident Timelines
Produces: OC-1 RootCauseReport; OC-2 RemediationPlan; optional OC-3..OC-6

Safety and abuse prevention [Informative]

kill_switch if evidence integrity missing or decision_basis incomplete; rate-limit KB PRs; require secondary approver for CrownJewels-impacting plans

Testing and validation [Informative]

contract tests for OC schemas; replay historical incidents; mutation tests (remove key evidence) to ensure claim weakening; hallucination bounds checks

Deployment and lifecycle [Informative]

HPA on RCA queue depth; canary model rollout; SBOM and SLSA attestations; sign all outputs

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-61 Rev. 2; NIST SP 800-137; NIST SP 800-53 Rev. 5 (PM, RA, IR, CP); NIST CSF 2.0; MITRE ATT&CK/D3FEND; ISO 27035

MCP-Native Protocol Specification (G5) [Normative]

(Canonical schemas and validation live here; keep example payloads synchronized with the Agent Blueprint.)

- **Native Protocol(s) Consumed:** RCAFindings (REST/Kafka/AMQP JSON); Incident Timelines (REST/JSON)
- **Native Protocol(s) Produced:** RootCauseReport (REST/JSON or Git PR); RemediationPlan (REST/JSON to change/baseline/patch queues)
- **MCP Context Fields:**
 - **Required:** mission_id; role="RCAAnalysisAgent"; intent="analyze"; decision_basis with evidence_refs **and** explanation_ref; provenance (SPIFFE ID, signing KID, attestation)
 - **Optional:** policy_refs (IR-4, IR-5, CP-2, PM-5); classification (C2–C3); constraints (publish_to_kb, redact_pii); legal_hold
- **Enforcement Note:** Must validate presence of decision_basis.evidence_refs and explanation_ref; enforce classification and redact_pii before KB publication; record evidence_refs for every recommendation.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry (see Schema Capsules).
- **Example payloads:** authoritative native + MCP-wrapped examples as above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url for downstream UIs/APIs.

Conformance: This section is [Normative] and, together with each **Schema Capsule**, defines testable requirements.

G6. Communications Agent

Agent Blueprint [Informative]

Purpose: Manage incident communications end-to-end: generate and route accurate, time-bounded **CommsBulletin** updates to the right audiences, enforcing message classification and distribution constraints (need-to-know, legal, regulatory).

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Incident Updates** (Incident Mgmt REST/JSON): incident_id, title, severity, phase, last_major_action, business_impact, stakeholder_audiences, next_update_due, regulatory_clock_start, requested_comms, links.
- **Comms Policies** (Git/REST): classification_matrix, audience_matrix, distribution_rules, templates, regulatory_triggers.

Model training / knowledge (what the LLM relies on):

- Comms rubric: clarity, accuracy, time-bounding, prohibited claims, safe language under investigation, attorney–client privilege patterns.
- RAG sources: incident runbooks, comms policy repo, audience directory, prior bulletins, regulator trigger catalog. Do not train on regulated evidence; fetch via evidence_refs only.
- Guardrails: classification must be chosen via policy matrix; enforce constraints (distribution: need_to_know, no_external_forwarding, cadence bounds); channel allowlist per audience.

Decisions it makes (deterministic + model-assisted):

- **Classification gate:** select C1/C2/C3 from severity×phase matrix; deny downgrade without HITL.
- **Audience targeting:** compute audience set from audience_matrix and requested_comms; expand to named recipients.
- **Regulatory trigger check:** if regulatory_clock_active and trigger met, propose RegulatoryNotificationEvent.
- **Cadence manager:** ensure ETA for next update; raise CadenceBreachAlert if overdue.
- **Messaging synthesis:** assemble subject/body using approved templates and incident facts; redact sensitive fields for C1/externals.

Routing / where outputs go:

- **CommsBulletin** → email/chat/status page/ticket comments; attach classification and constraints; record distribution audit trail.
- Optional: **RegulatoryNotificationEvent** → privacy/legal workflow;
StatusPageUpdate → external status platform.

Automation scope vs. manual/HITL:

- Fully automated: template fill, audience resolution, classification per matrix, channel routing, distribution audit, cadence tracking.
- **HITL required:** any C1 public bulletin; classification downgrade (e.g., C3→C2/C1); bullets that discuss attribution, customer PII, legal exposure; regulator notifications in new jurisdictions.
- Manual outside agent: press/media Q&A, investor relations, executive brief approvals for external statements.

Security Domain: Incident Response & Digital Forensics (IR/DFIR)

Inputs (native protocols consumed) [Informative]

1. **Incident Updates (Incident Mgmt REST/JSON)** — authoritative incident facts and cadence.
2. **Comms Policies (Git/REST)** — matrices, rules, templates, triggers.

Example: Consumed Protocol — Incident Updates [Informative]

Native payload

```
{  
  "incident_id": "INC-45877",  
  "title": "Privilege escalation on srv-001 affecting Payments API",  
  "severity": "High",  
  "current_phase": "Containment",  
  "last_major_action": {"ts": "2025-08-15T10:01:23Z", "action": "isolate_host", "target":  
    "srv-001"},  
  "business_impact": {"services": ["payments-api"], "customer_visible":  
    "minor_degradation", "regions": ["us-east-1"]},
```

```

"stakeholder_audiences": ["exec", "legal", "it_ops", "security_ir"],
"next_update_due": "2025-08-15T10:20:00Z",
"regulatory_clock_start": "2025-08-15T10:02:00Z",
"requested_comms": [{"audience": "exec", "cadence_minutes": 15}, {"audience":
"it_ops", "cadence_minutes": 10}],
"links": {"runbook": "uri://git/dr/runbooks/RP-2025-08-15-PAYMENTS-AZ1.json",
"channel_war_room": "uri://chat/rooms/ir-war-room-INC-45877"}
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-g6-comms-1111-2222-3333-4444",
    "thread_id": "uuid-inc-INC-45877",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "CommunicationsAgent",
    "intent": "communicate",
    "policy_refs": ["IR-4", "IR-8", "AU-6"],
    "classification": "C2",
    "constraints": ["distribution:internal_need_to_know",
"cadence:exec=15m,it_ops=10m", "no_external_forwarding:true"],
    "decision_basis": {
      "evidence_refs": ["uri://incident/api/incidents/INC-45877"],
      "confidence": 0.97,
      "explanation_ref": "uri://kb/comms/incident-bulletin-cadence"
    },
    "provenance": {"producer_spiffe": "spiffe://enterprise/ir/communications-agent",
"signing_kid": "kid-inc-g6-01", "attestation_ref":
"uri://slsa/attestations/communications@sha256:inc01"},

```

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

```

    "legal_hold": true
  },
  "native_payload": { ... }
}

```

Example: Consumed Protocol — Comms Policies [Informative]

Native payload

```

{
  "policy_id": "IR-COMMS-STD-2025",
  "classification_matrix": [
    {"severity": "Critical", "phase": "Containment", "classification": "C3"},
    {"severity": "High", "phase": "Containment", "classification": "C2"}
  ],
  "audience_matrix": {
    "exec": ["CISO", "CTO", "CFO", "CEO"],
    "legal": ["general_counsel", "privacy_officer"],
    "it_ops": ["noc_manager", "oncall_sre"]
  },
  "distribution_rules": [
    "no_external_forwarding",
    "bcc_legal_when:regulatory_clock_active",
    "status_page_only_if:customer_visible in ['major_outage','data_breach_confirmed']"
  ],
  "templates": {
    "internal_update_v1": "Incident {incident_id} ({severity}) — Phase: {phase}. Impact: {impact}. Last action: {last_action}. Next update by {next_update_due}.",
    "exec_update_v1": "Exec Brief — {title}. Sev {severity}. Impact: {impact_summary}. Containment: {containment_summary}. Risks: {key_risks}. ETA next update {next_update_due}."
  }
}

```

```

},
"regulatory_triggers": {
  "breach_confirmed": {"notify_within_hours": 72, "owners": ["privacy_officer", "legal"]},
  "pii_exposed": {"notify_regulators": true}
}
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-g6-comms-1111-2222-3333-4444",
    "thread_id": "uuid-policy-IR-COMMS-STD-2025",
    "task_id": "uuid-ee11-ff22-0011-2233",
    "role": "CommunicationsAgent",
    "intent": "communicate",
    "policy_refs": ["IR-8", "PM-9"],
    "classification": "C2",
    "constraints": ["distribution:internal_need_to_know", "no_external_forwarding:true",
"bcc:legal_when_regulatory_clock_active"],
    "decision_basis": {
      "evidence_refs": ["uri://git/policies/IR-COMMS-STD-2025.json"],
      "confidence": 0.95,
      "explanation_ref": "uri://kb/comms/templates/internal_update_v1"
    },
    "provenance": {"producer_spiffe": "spiffe://enterprise/ir/communications-agent",
"signing_kid": "kid-pol-g6-02", "attestation_ref":
"uri://slsa/attestations/communications@sha256:policy02"},
    "legal_hold": true

```

```
},  
  "native_payload": { ... }  
}
```

Outputs (native) [Informative]

- **CommsBulletin** (REST/Kafka/AMQP) for email/chat/status page/ticket comments; includes classification and enforced constraints.

MCP context (required) [Informative]

mission_id; role="CommunicationsAgent"; intent="communicate"; provenance (SPIFFE ID, signing KID, attestation); classification (C1/C2/C3); constraints (distribution, recipients, embargoes, cadence, no_external_forwarding)

MCP context (optional) [Informative]

policy_refs (IR-4, IR-8, AU-6, PM-9); decision_basis (evidence_refs, confidence, explanation_ref to template/policy); legal_hold

Enforcement note [Informative]

PEPs MUST enforce classification, recipients, and distribution rules; MUST block forwarding where **no_external_forwarding:true**; MUST ensure BCC to legal when regulatory_clock_active; MUST record DistributionAuditTrail.

NIST SP 800-160v2 linkage [Informative]

Respond & Learn — disciplined communications as resilience control; aligns with NIST SP 800-61 (coordination/communication) and NIST SP 800-53 IR-4/IR-8.

Automation feasibility [Informative]

High: templating, routing, classification checks, and cadence enforcement automate well; HITL for public/regulated notices.

Output Contracts (merged) [Informative]

(OC-1/OC-2 are primary. OC-3..OC-6 provide enterprise extensions.)

OC-1: CommsBulletin [Informative]

- **Producer(s):** G6
- **Topic/Path:** sec.ir.comms.bulletin (REST: POST /comms/bulletins)

- **Schema/Format:** CommsBulletin@1.3 (bulletin_id, incident_id, audience, channel, classification, constraints[], subject, body, attachments[], recipients[], bcc[], sent_at, next_update_due, regulator_flags)
- **Classification:** C1–C3 (enforced)
- **Delivery:** at-least-once
- **Ordering:** per-incident_id, per-audience
- **Idempotency-Key:** sha256(incident_id, audience, sent_at_floor_60s)
- **Ack/Nack:** 201 Created or channel message_id; schema reject → NACK
- **Timeouts/Retry:** ack<=15s; exp-backoff<=5x
- **Side-Effects:** write DistributionAuditTrail entry; schedule next update
- **HITL Token:** required for C1/public or classification change
- **Observability:** trace_id, mission_id, classification_label, decision_basis.*, provenance.attestation
- **Retention/TTL:** 1 year (extend if legal_hold)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=CommsBulletin@1.3 | json_schema_uri=uri://schema/comms-bulletin-1.3.json | sha256= | producers=G6 | consumers=Mail-01, Chat-01, Status-01, Ticket-01, Audit-Journal-01 | accepts=1.2–1.3

OC-2: DistributionAuditTrail [Informative]

- **Producer(s):** G6
- **Topic/Path:** sec.ir.comms.audit
- **Schema/Format:** DistributionAuditTrail@1.1 (bulletin_id, channel, recipients[], delivered[], failed[], classification, constraints_enforced[], message_hash, delivery_latency_ms)
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-bulletin_id

- **Idempotency-Key:** sha256(bulletin_id, channel)
- **Ack/Nack:** broker ACK; retry/backoff
- **Side-Effects:** feed SIEM for traceability; alert on failed delivery > threshold
- **HITL Token:** none (read-only audit)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When classification != C1 or constraints include no_external_forwarding / regulatory_clock_active

schema_id=DistributionAuditTrail@1.1 | json_schema_uri=uri://schema/distribution-audit-1.1.json

OC-3: RegulatoryNotificationEvent [Informative, optional]

- **Producer(s):** G6, Privacy/Legal portals
- **Topic/Path:** sec.ir.comms.regulatory
- **Schema/Format:** RegulatoryNotificationEvent@1.0 (incident_id, trigger, jurisdiction, deadline, owners[], notice_channel, sent_at)
- **Classification:** C2+
- **Delivery/Ordering:** at-least-once; per-incident_id
- **Idempotency-Key:** sha256(incident_id, jurisdiction, trigger)

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When regulatory_clock_active and trigger conditions met

schema_id=RegulatoryNotificationEvent@1.0 |
json_schema_uri=uri://schema/regulatory-notice-1.0.json

OC-4: StatusPageUpdate [Informative, optional]

- **Producer(s):** G6
- **Topic/Path:** ext.status.update (REST: POST /status/updates)
- **Schema/Format:** StatusPageUpdate@1.0 (incident_id, status, impact_summary, regions[], eta_next_update, public_url)
- **Classification:** C1

- **Delivery/Ordering:** exactly-once per public_url
- **Idempotency-Key:** sha256(incident_id, public_url, sent_at_floor_60s)

Schema Capsule (OC-4) [Normative]

Requirement Level: Conditionally Required

Condition: When policy rule status_page_only_if evaluates true
 schema_id=StatusPageUpdate@1.0 | json_schema_uri=uri://schema/status-page-update-1.0.json

OC-5: CommsDispute (Explainability/Contestability) [Informative, optional]

- **Producer(s):** G6, Exec/Legal portals
- **Topic/Path:** sec.ir.comms.contestation
- **Schema/Format:** CommsDispute@1.0 (bulletin_id, dispute_id, rationale_url, requested_change)
- **Classification:** C2
- **Delivery/Ordering:** at-least-once; per-bulletin_id

Schema Capsule (OC-5) [Normative]

Requirement Level: Optional

Condition: When contestability workflow is enabled
 schema_id=CommsDispute@1.0 | json_schema_uri=uri://schema/comms-dispute-1.0.json

OC-6: CadenceBreachAlert [Informative, optional]

- **Producer(s):** G6
- **Topic/Path:** sec.ir.comms.cadence_breach
- **Schema/Format:** CadenceBreachAlert@1.0 (incident_id, audience, expected_due, actual_time, lateness_sec, reason, corrective_action)
- **Classification:** C1
- **Delivery/Ordering:** at-least-once; per-incident_id,audience

Schema Capsule (OC-6) [Normative]

Requirement Level: Conditionally Required

Condition: When next_update_due is missed

schema_id=CadenceBreachAlert@1.0 | json_schema_uri=uri://schema/cadence-breach-1.0.json

State machine (concise) [Informative]

states = { idle, ingesting_updates, drafting_bulletin, classification_gate, hitl_review, distributing, awaiting_acks, embargoed, monitoring_cadence, contestation_workflow, failed, closed }

transition(idle -> ingesting_updates) when Incident Update arrives

transition(ingesting_updates -> drafting_bulletin) when policy loaded and next_update_due <= T_now + tolerance

transition(drafting_bulletin -> classification_gate) when content composed

transition(classification_gate -> hitl_review) when classification in {C1} or downgrade requested

transition(classification_gate -> distributing) when auto-allowed (e.g., C2 internal)

transition(distributing -> awaiting_acks) when sends queued

transition(awaiting_acks -> monitoring_cadence) when ack_ratio >= threshold

transition(* -> embargoed) when embargo constraint present and not lifted

transition(monitors_cadence -> drafting_bulletin) when next_update_due imminent

transition(* -> contestation_workflow) when CommsDispute opened

transition(* -> failed) on schema_error, routing_failure, or policy_violation

idempotency_key(OC-1) = sha256(incident_id, audience, sent_at_floor_60s)

idempotency_key(OC-2) = sha256(bulletin_id, channel)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 CommsBulletin	Required	Always	Core incident communications
OC-2 DistributionAuditTrail	Conditionally Required	classification != C1 or forwarding/regulatory constraints set	Auditability and control evidence
OC-3 RegulatoryNotificationEvent	Conditionally Required	Regulatory clock active and trigger met	Compliance with statutory deadlines

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-4 StatusPageUpdate	Conditionally Required	Policy rule allows public status update	Customer transparency
OC-5 CommsDispute	Optional	Contestability enabled	Governance and explainability
OC-6 CadenceBreachAlert	Conditionally Required	next_update_due missed	Operational discipline and escalation

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- policy_refs: IR-4, IR-8, AU-6, PM-9 (+ internal comms standards)
- **HITL required:** any C1/public message; classification downgrade; messages referencing attribution, customer data, or legal exposure; regulator notices in new jurisdictions
- Automatic HITL triggers: model_confidence < theta_low; stakeholder_disagreement_score >= 0.5; legal_hold=true; embargo present
- Manual outside agent: media interviews, investor relations, regulatory filings text

SLOs and KPIs [Informative]

- BulletinLatency_p95 <= 5 minutes from next_update_due
- DeliverySuccessRate_p99 >= 99.5 percent
- MisroutingRate_30d <= 0.1 percent
- CadenceBreachRate_30d <= 1 percent
- PublicBulletinApprovalLeadTime_p95 <= 20 minutes

Outputs index [Informative]

[OC-1 CommsBulletin], [OC-2 DistributionAuditTrail], [OC-3 RegulatoryNotificationEvent], [OC-4 StatusPageUpdate], [OC-5 CommsDispute], [OC-6 CadenceBreachAlert]

Technical Implementation Details (G6) [Informative]

Model and training profile [Informative]

model_id=comms-orchestrator; temperature=0.15; max_tokens_out=700
prompt_pack_id=incident-comms-v1 (tone guardrails, classification matrix rules, template library)
RAG: sources={comms policy repo, audience directory, prior bulletins, regulator triggers}; max_docs=10; min_similarity=0.8; citations required
fine_tuning/adapters: optional on anonymized internal bulletins; eval on accuracy, classification correctness, and prohibition adherence
guardrails: channel allowlist; regex blocks for speculative attribution; token scopes per channel

Memory and state [Informative]

working_memory.max_tokens=3k; eviction=recency_then_importance
episodic_memory: per mission_id journal (bulletins, acknowledgements, disputes), ttl=180d
semantic_memory: namespaces=["templates", "audiences", "incidents"];
embeddings=text-embedding-sec-v1; k=10
durable_state_store: event-sourced; snapshot after each distribution round
consistency: at-least-once for OC-1; exactly-once for OC-2 entries per bulletin_id,channel

Decision and routing logic [Informative]

classification = policy_matrix(severity, phase)
audience_set = union(requested_comms.audiences, audience_matrix[stakeholder_audiences])
regulatory_clock_active = (now - regulatory_clock_start) <= regulatory_window
next_eta = min(requested_cadence_by_audience)
cadence_breach = now > next_update_due + grace

Model Risk Management [Informative]

continuous_validation: daily eval on historical incidents; adversarial tests (prompt injection via incident titles, template tampering)
thresholds: eval_pass_rate >= 99.0 percent; otherwise auto_HITL for all C1/C2 bulletins

red_team_cycle: monthly tests for leakage, misclassification, and audience misrouting
rollback_policy: if MisroutingRate_7d > 0.2 percent → revert model_id; notify owners

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: classification_reason, policy_rule_refs,
audience_resolution_log, constraints_applied
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL; stable field order; link OC-1 to OC-2 entries

Incident/Program Integration [Informative]

emit CommsBulletin (OC-1); write DistributionAuditTrail (OC-2); raise
RegulatoryNotificationEvent (OC-3) when triggered; create StatusPageUpdate (OC-4)
per policy

Feedback & Learning [Informative]

accept CommsDispute (OC-5); incorporate approved edits into templates; never auto-
train on privileged/legal content

Data Sovereignty and Legal Hold [Informative]

respect region for distribution (email/chat/status); legal_hold=true → extend TTL and
restrict external channels

Interfaces (links only) [Informative]

Consumes: Incident Updates; Comms Policies
Produces: OC-1..OC-6 as implemented

Safety and abuse prevention [Informative]

kill_switch on misclassification detected; embargo enforcement; rate-limits on broadcast
channels; prevent CC to external domains on C2/C3

Testing and validation [Informative]

contract tests for OC schemas; policy-matrix unit tests; simulated regulator triggers;
channel delivery mocks and retries

Deployment and lifecycle [Informative]

HPA on audience size and bulletin rate; canary model rollout; SBOM and SLSA
attestations; sign all outputs

References / Standards [Informative]

MCP-Native Protocol Specification (G6) [Normative]

- **Native Protocol(s) Consumed:** Incident Updates (REST/JSON); Comms Policies (Git/REST)
- **Native Protocol(s) Produced:** CommsBulletin (REST/Kafka/AMQP); optional RegulatoryNotificationEvent; StatusPageUpdate; DistributionAuditTrail
- **MCP Context Fields:**
 - **Required:** mission_id; role="CommunicationsAgent"; intent="communicate"; provenance (SPIFFE ID, signing KID, attestation); classification; constraints
 - **Optional:** policy_refs; decision_basis (evidence_refs, confidence, explanation_ref); legal_hold
- **Enforcement Note:** PEPs MUST validate classification and constraints for each channel; MUST block forwarding if no_external_forwarding:true; MUST persist DistributionAuditTrail entries.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry (see Schema Capsules).
- **Example payloads:** authoritative native + MCP-wrapped examples included above.
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.